

A fase de preparação da resposta a incidentes identifica fontes de dados que podem ajudar nas investigações. Ela também fornece ferramentas para agregar e correlacionar esses dados e automatizar parcialmente a sua análise, de modo a gerar um sistema de alerta e monitoramento. Embora a detecção automatizada seja de grande ajuda para a equipe de segurança, ela não consegue identificar todos os indícios de atividades mal-intencionadas. Como agente de resposta, você deve ser capaz de identificar sinais nas fontes de dados que indiquem um tipo específico de ataque.

Nesta lição, você vai fazer o seguinte:

- Analisar indícios de atividades mal-intencionadas em ataques de malware, físicos, de rede e de aplicações.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Ao classificar os vários tipos de malware e identificar os sinais de infecção, as equipes de segurança estão mais bem preparadas para corrigir sistemas comprometidos ou impedir a execução de malware.

Objetivos abordados no exame:

- Considerando determinado cenário, analisar os indicadores de atividade maliciosa.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

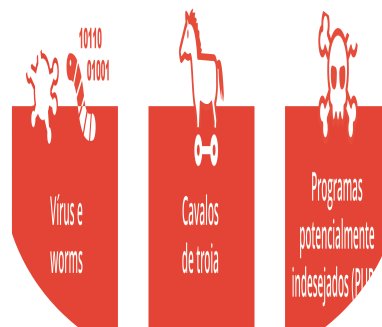
Muitas das tentativas de intrusão em redes de computadores dependem do uso de software maliciosos ou malwares.

[[Malware]] é simplesmente definido como um software que realiza alguma ação prejudicial, do ponto de vista do proprietário do sistema. Um fator complicador na classificação dos malwares é o grau em que sua instalação é esperada ou tolerada pelo usuário.

Algumas classificações de malware, como cavalo de troia, vírus e worm, se concentram no vetor usado pelo malware. O vetor é o método pelo qual o malware é executado em um computador e se espalha potencialmente para outros hosts da rede. As seguintes categorias descrevem alguns tipos de malware de acordo com o vetor:

- Vírus e worms representam alguns dos primeiros tipos de malware e se espalham sem qualquer autorização do usuário, sendo ocultados dentro do código executável de outro processo. Esses processos são descritos como infectados por malware.
- Cavalo de [[troia]] refere-se ao malware escondido dentro de um pacote instalador de software que parece ser legítimo. Esse tipo de malware não busca nenhum tipo de consentimento para a instalação e é projetado para operar secretamente.
- [[Programas potencialmente indesejados (PUPs)]] / Aplicativos potencialmente indesejados (PUAs) são softwares instalados juntamente com um pacote escolhido pelo usuário ou, eventualmente, incluídos em um novo sistema computacional. Ao contrário do cavalo de troia, a presença de um PUP não é automaticamente considerada uma ação mal-intencionada. Ele pode ter sido instalado sem consentimento ativo ou com o consentimento de um contrato de licença intencionalmente confuso. Esse tipo de software às vezes é classificado como *grayware* em vez de malware. Ele também pode ser chamado de “bloatware”.

Figura 1. Classificação de malwares por vetor.



Outras classificações são baseadas na carga útil entregue pelo malware. O *payload* é uma ação executada pelo malware além de simplesmente se replicar ou persistir em um host. Os exemplos de classificações de payload incluem: spyware, rootkit, cavalo de troia por acesso remoto e ransomware.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Malware = ação prejudicial do ponto de vista do proprietário do sistema. É difícil de classificar um malware pelo grau em que sua instalação é esperada ou tolerada pelo usuário. Casos como os de ativadores do Windows seria um caso bem comum onde o usuário sabe que corre risco usando um software que não é licenciado e que pode conter vírus. Alguns tipos de malwares se concentram no vetor que vai usá-los. Alguns tipos de malwares classificados e seus vetores:

Vírus e Worms: não precisam de autorização do usuário e são executados dentro do código executável de outro processo.

Cavalo de troia: vem escondido dentro de um pacote de instalador de software que parece ser legítimo, mas não é. Esse malware não busca nenhum consentimento do usuário para instalação e ele é projetado para agir secretamente.

Programas potencialmente indesejáveis (PUPs): esses são os clássicos que vem com algum software que você queria instalar, mas nas letras miúdas lá em baixo, não desmarcou a caixa de "instalar software barata da pqp kkkkk". Nesse momento, acaba também sendo instalado um software que você não queria que estivesse na sua máquina. Ele tem o nome de grayware ou blotware. Dito isso, os PUPs não são classificados como uma classe de softwares mal intervencionados pelo seu contrato de consentimento confuso e bagunçado de propósito para que o usuário aceite.

Um [[vírus]] de computador é um tipo de malware projetado para se replicar e se espalhar de computador para computador, geralmente "infectando" aplicativos executáveis ou código de programas. Existem muitos tipos de vírus, geralmente classificados de acordo com os diferentes tipos de arquivos ou mídias que infectam:

- **Não residente/infectador de arquivos:** o vírus está dentro de um arquivo executável do host e é executado com o processo host. Ele tentará infectar outras imagens de processo no armazenamento persistente e executar outras ações de payload. Em seguida, ele passa o controle de volta para o programa host.
- **Residente na memória:** quando o arquivo host é executado, o vírus cria um processo para si mesmo na memória. O [[processo mal-intencionado]] permanece na memória, mesmo que o processo host seja encerrado.
- **Inicialização:** o código do vírus é gravado no setor de inicialização do disco ou na tabela de partição de um disco fixo ou mídia USB e é executado como um processo residente na memória quando o sistema operacional é iniciado ou a mídia é conectada ao computador.
- **Vírus de script e macro:** o malware utiliza os recursos de programação disponíveis em mecanismos locais de script do sistema operacional e/ou navegador, como PowerShell, Windows Management Instrumentation (WMI), JavaScript, documentos Microsoft Office com código VBA (Visual Basic for Applications) habilitado ou documentos PDF com JavaScript ativado.

Além disso, o termo "multiparte" é usado para designar vírus que usam múltiplos vetores, e "polimórfico" para vírus que conseguem alterar ou ocultar dinamicamente seu código para evitar a detecção.

O que esses tipos de vírus têm em comum é o fato de que eles precisam infectar um arquivo host ou mídia. Um arquivo infectado pode ser distribuído por qualquer meio normal — em um disco, uma rede, como anexo de e-mail ou publicação em rede social ou como um arquivo baixado de um site.

Figura 1. Anexo inseguro detectado pelo filtro de e-mails do Outlook — A extensão de arquivo “dupla” é uma tentativa pouco sofisticada de enganar usuários que não estejam atentos ao uso de inglês e holandês no texto da mensagem.



Captura de tela usada com permissão da Microsoft.

Descrição

A mensagem no topo diz: links e outras funcionalidades foram desativados nesta mensagem. Para ativar essa funcionalidade, mova esta mensagem para a Caixa de Entrada. Esta mensagem foi marcada como spam por um filtro de lixo eletrônico diferente do filtro de Lixo Eletrônico do Outlook. Convertimos esta mensagem para o formato de texto simples. O Outlook bloqueou o acesso aos seguintes anexos potencialmente inseguros:

Docx_2017082407_095451_PDF.jar. Uma mensagem é seguida por um e-mail.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Como o nome mesmo já diz, um vírus é aquilo que se propaga, contamina, se espalha com facilidade, nesse caso, em máquinas. Assim como os malwares são classificados e tem suas distinções, os vírus também tem. São divididos de acordo com diferentes tipos de arquivos ou mídias infectadas:

Não residente/infectador de arquivos: ele é somente um visitante que está alocado dentro de um software .exe por exemplo. Ele é executando junto do programa ou ante mesmo antes do programa rodar na sua máquina. Deixa resquícios em outros arquivos e lugares dentro da máquina. Quando fecha o software, fecha o vírus.

Residente na memória: cria um processo para si mesmo dentro da memória do computador, sem a autorização do proprietário, com a finalidade de danificar ou comprometer o sistema.

Inicialização: só tem o seu "acordar" quando é chamado na tabela de partição de inicialização do sistema operacional. Essa tabela poder estar no disco rígido da máquina ou em um pen drive USB.

Vírus de script e macro: já usa ferramentas do próprio sistema para realizar processos de infecção. Pode ser por meios de VML, JavaScript, pacote Office com VBA habilitado, documentos pdf com JavaScript ativado e PowerShell.

O termo "**multiparte**" por ser atribuído para designar vírus que usam múltiplos vetores e "**polimorfismo**" para desfaçar dinamicamente seus códigos para não serem detectados. Todos eles tem uma coisa em comum: precisam de um arquivos ou mídia para infectar o host. Esse arquivo ou mídia pode ser compartilhado por todos os meios comuns conhecidos.

O que esses vírus tem em comum é que eles precisam infectar algum arquivo ou mídia para agirem. Os arquivos e mídias podem ser compartilhado por quase todas as formas na internet.

Um [[worm]] de computador é um malware que reside na memória e pode ser executado sem a intervenção do usuário e ser reproduzido nos recursos da rede. Um vírus é executado apenas quando o usuário executa uma ação, como baixar e executar um processo executável infectado, conectar um pendrive infectado ou abrir um documento infectado com macros ou scripts ativados. Por outro lado, um worm pode ser executado ao explorar uma vulnerabilidade em um processo quando o usuário navega em um site, executa um aplicativo de servidor vulnerável ou está conectado a um compartilhamento de arquivo infectado. Por exemplo, o worm Code Red conseguiu infectar versões anteriores do software de servidor web IIS da Microsoft por meio de uma vulnerabilidade de buffer overflow. Em seguida, ele verificou sequências de IP geradas aleatoriamente para tentar infectar outros servidores IIS vulneráveis.

O principal efeito dos primeiros tipos de worm de computador é o consumo rápido de largura de banda de rede enquanto ele se replica. O worm também pode travar o sistema operacional ou o aplicativo do servidor, realizando um ataque de negação de serviço. Além disso, assim como os vírus, os worms conseguem transportar um payload que pode ser gravada para executar qualquer tipo de ação mal-intencionada.

O worm Conficker demonstrou o potencial que a execução remota de código e o malware residente na memória têm para efetuar ataques altamente eficazes. À medida que os malwares continuaram sendo desenvolvidos para fins criminosos e os softwares de segurança se tornaram mais capazes de detectar e bloquear ameaças estáticas, os códigos e as técnicas dos malwares se tornaram mais sofisticados. O termo "fileless" (sem arquivo) ganhou destaque para se referir a esses tipos modernos de malware. Fileless não é uma classificação definitiva, mas descreve um conjunto de comportamentos e técnicas comuns:

- O malware fileless não grava seu código no disco. Ele usa técnicas residentes na memória para ser executado no seu próprio processo, dentro de um processo de host ou biblioteca de links dinâmicos (DLL) ou, ainda, dentro de um host de script. No entanto, isso não resulta em ausência de atividade no disco. O malware pode alterar os valores do registro para alcançar persistência (ser executado se o computador hospedeiro for reiniciado). A execução inicial do malware também pode depender da ação do usuário, como na execução de um script baixado, anexo de arquivo ou pacote de software de cavalo de troia.
- Malware fileless utiliza [[shellcode]] leve para obter um mecanismo de backdoor no host. O shellcode consegue se recompilar facilmente de forma ofuscada para evitar a detecção por scanners. Em seguida, ele consegue baixar pacotes ou payloads adicionais para atingir os objetivos do autor da ameaça. Esses pacotes também podem ser ofuscados, transmitidos e compilados em tempo real para evitar a detecção automatizada.

- Os malwares fileless podem usar técnicas de “live off the land” (LoTL) (sobreviver dos recursos locais) em vez de arquivos executáveis compilados para evitar a detecção. Isso significa que o código do malware usa ferramentas legítimas de script do sistema, principalmente o PowerShell e o Windows Management Instrumentation (WMI), para executar ações do payload. Se o malware conseguir ser executado com permissões suficientes, os ambientes fornecem todas as ferramentas de que o invasor precisa para realizar uma varredura, reconfigurar as configurações e exfiltrar dados.

Os termos “[ameaça persistente avançada]” (APT) e “ameaça volátil avançada” (AVT) podem ser usados para descrever essa classe geral de malware moderno LoTL e fileless. Outra classificação útil é o “ataque de características pouco observáveis” (LOC). A classificação exata é menos importante do que perceber que os opositores podem usar qualquer tipo de truque de código para efetuar invasões e que suas táticas, suas técnicas e seus procedimentos para evitar a detecção estão em constante evolução.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

O que é um worm ?

Diferente o vírus que precisa de uma interação do usuário para funcionar, um worm pode ser executado ao explorar uma vulnerabilidade em um processo quando o usuário navega em um site, executa um aplicativo de servidor vulnerável ou está conectado a um compartilhamento de arquivo infectado. Um worm não precisa necessariamente de uma ação do usuário para que ele funcione dentro da rede. Ele é um malware que reside na memória. A proposta dele é se espalhar cada vez mais rápido pela rede e sendo o principal efeito nos primeiros tipos de worms, era ocupar largura de banda e causar lentidão extrema em qualquer ação dentro dela enquanto o worm se replica. Um worms pode executado de diversas maneiras na rede, sendo elas como já dissemos ocupando largura de banda, realizando ataques de negação de serviço e até mesmo carregando payloads para ativações futuras.

Nessa corrida de gato e rato, um termo ganhou notoriedade entre os worms, o fileless (sem arquivos). Conforme descrito no texto, fileless não é uma classificação para esse tipo de vírus, mas sim um conjunto de comportamento e técnicas comuns realizadas:

Métodos e Comportamentos do Malware Fileless

- **Execução Residente na Memória:** O malware fileless não grava seu código malicioso diretamente no disco rígido. Em vez disso, ele utiliza técnicas para residir e ser executado estritamente na memória do sistema (RAM). Essa execução pode ocorrer dentro de um processo próprio, dentro de um processo de host legítimo ou injetado em uma biblioteca de links dinâmicos (DLL).
- **Modificação do Registro para Persistência:** Embora a atividade ocorra na memória, o malware pode interagir com o disco de forma indireta. Ele altera valores do registro do sistema operacional para garantir persistência, permitindo que o código malicioso seja reexecutado caso o computador hospedeiro seja reiniciado.
- **Dependência de Ação Inicial do Usuário:** A execução inicial do vetor fileless ainda pode depender de uma interação humana para entrar no sistema. Isso inclui a execução de scripts baixados da internet, abertura de anexos de e-mail ou a execução de pacotes de software que agem como cavalos de troia.
- **Uso de Shellcode Leve e Ofuscado:** O malware emprega um mecanismo de *shellcode* leve para estabelecer um *backdoor* (porta dos fundos) no host. Esse *shellcode* possui capacidade de se recompilar de forma ofuscada para burlar scanners de segurança tradicionais. A partir daí, o código baixa payloads adicionais que também podem ser transmitidos e compilados em tempo real para evitar a detecção automatizada estática.
- **Técnicas "Live off the Land" (LoTL):** Para evitar o uso de arquivos executáveis compilados suspeitos, o malware "sobrevive dos recursos locais". Isso significa que ele sequestra e utiliza ferramentas legítimas e nativas de script do próprio sistema operacional. As ferramentas prioritárias exploradas no ecossistema Windows são o **PowerShell** e o **Windows Management Instrumentation (WMI)**. Caso o malware obtenha privilégios de execução suficientes, esses ambientes nativos fornecem todos os recursos necessários para que o invasor realize varreduras de rede, reconfigure o sistema e faça a exfiltração de dados confidenciais.

-
- **Classificações Equivalentes:** Os termos **Ameaça Persistente Avançada (APT)** e **Ameaça Volátil Avançada (AVT)** são utilizados de forma intercambiável para categorizar a classe geral de malwares modernos que operam sem arquivos em disco e abusam de recursos nativos do sistema hospedeiro.
 - **Ataque de Características Pouco Observáveis (LOC):** É uma classificação técnica útil para descrever a natureza furtiva dessas invasões, que deixam poucos vestígios ou artefatos para análise forense tradicional.
 - **Evolução e Foco Operacional:** A taxonomia ou o nome exato dado ao malware é secundária. O fator crítico para a defesa é compreender que os atacantes utilizam qualquer manipulação de código disponível para romper o perímetro, e que suas **Táticas, Técnicas e Procedimentos (TTPs)** para evasão de defesas estão em constante mutação.

Os primeiros vírus e worms se concentraram no potencial destrutivo da autorreplicação. À medida que os usos lucrativos desse tipo de software se tornaram aparentes, no entanto, eles começaram a ser codificados com payloads projetados para facilitar invasões, fraudes e roubo de dados. Os bloatwares e malwares podem ser usados para diferentes níveis de monitoramento:

- **Cookies de rastreamento:** um cookie é um arquivo de texto simples, não é um malware, mas, se permitido pelas configurações do navegador, os cookies de terceiros podem ser usados para registrar atividades na web, rastrear o endereço IP do usuário e coletar vários outros metadados, como consultas de pesquisa e informações

sobre o software e a configuração do navegador. Os cookies de rastreamento são criados por anúncios e widgets de análise incorporados em muitos sites.

- **Supercookies e beacons**: como os softwares dos navegadores dão ao usuário algum controle sobre quais cookies aceitar, as empresas de marketing na web criaram maneiras alternativas e mais difíceis de desativar para implementar o rastreamento. Um supercookie é um meio de armazenar dados de rastreamento de maneira não regular, como salvá-los no cache sem declarar que os dados são um cookie ou codificá-los em solicitações de cabeçalho. Um beacon é uma imagem de pixel único incorporada em um site. Embora invisível para o usuário, o navegador precisa fazer uma solicitação para baixar o pixel e carregar o site, dando ao host do beacon a oportunidade de coletar metadados e impressões digitais do navegador e, potencialmente, executar scripts de rastreamento.
- **[[Adwares]]**: esta é uma classe de bloatware/PUP (programa potencialmente indesejado) que reconfigura o navegador, por exemplo, permitindo cookies de rastreamento, alterando provedores de pesquisa padrão, abrindo páginas do patrocinador na inicialização, adicionando favoritos e assim por diante. Os adwares podem ser instalados como um programa ou como uma extensão/plug-in do navegador.
- **[[Spywares]]**: trata-se de um malware que consegue realizar um rastreamento parecido com o dos adwares, mas também monitora a atividade de aplicativos locais, faz capturas de tela e ativa dispositivos de gravação, como microfones ou webcams. Outra técnica de spyware é fazer o redirecionamento de DNS para sites de **[[pharming]]**.
- **[[Keyloggers]]**: tipo de spyware que tenta ativamente registrar as teclas digitadas para roubar informações confidenciais. O invasor geralmente espera descobrir senhas ou dados de cartão de crédito.

Figura 1. A ferramenta de acesso remoto Metasploit Meterpreter é usada para extrair as teclas digitadas na máquina vítima, revelando a senha digitada para acessar um aplicativo web.



Nota:

Os keyloggers não são implementados apenas como software. Um script mal-intencionado pode transmitir as teclas pressionadas para um site de terceiros. Há também dispositivos de hardware para capturar teclas pressionadas usando um adaptador USB modificado que é inserido entre o teclado e a porta. Esses dispositivos podem armazenar dados localmente ou utilizar conectividade Wi-Fi para enviar dados a um access point secreto. Outros tipos de ataque incluem o uso de detectores wireless para registrar os dados das teclas pressionadas, sobrepor teclados de senha de caixas eletrônicos e assim por diante.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Os vírus e worms tinha um objetivo centrado de autorreplicação e destruição geral do sistema operacional e arquivos. Ao longo dos tempos, os vírus foram se modificando para tornar fraudes, roubos de dados e facilitar invasões usando payloads, que começaram a ser codificado com eles.

Cookies de rastreamento: não é um malware, mas pode ser usado para descobrir localização, IP do computador informações, etc. Tudo isso é disponibilizado no site na primeiro acesso.

Supercookies e beacons: supercookies são formas de um cookie ficar armazenado no cache da memória sem se autodeclarar que é um cookie. Beacon está relacionado a coleta de dados po imagem, pixels que podem conter metadados do usuário.

Adware: abre portas que não estavam lá antes. Redefini configurações padrão de um navegador, coloca páginas de sites na inicialização do seu navegador, adiciona favoritos. Ele pode ser instalado com um software.

Spyware: faz captura de telas, monitora o que está fazendo e existe até um forma de spyware que redireciona o DNS para uma pharming.

Keyloggers: monitora ativamente informações do seu teclado para obter informações sensíveis, como por exemplo, dados de cartão de crédito, documentos sigilosos.

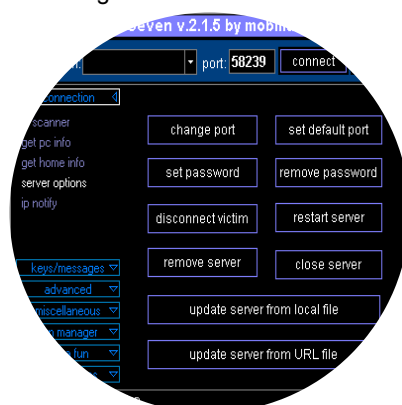
Pode-se chamar de [[backdoor]] qualquer tipo de método de acesso a um host que dribla o método de autenticação padrão e fornece controle administrativo ao usuário remoto. Um [[Trojan de acesso remoto (RAT)]] é um malware de backdoor que imita a funcionalidade de programas legítimos de controle remoto, mas é projetado especificamente para operar de forma oculta. Depois que o RAT é instalado, ele permite que o autor da invasão acesse o host, envie arquivos e instale software ou use técnicas de LoTL para causar ainda mais danos.

Nota:

Nesse contexto, a sigla RAT também pode designar uma ferramenta de administração remota. Um host sob o controle alheio mal-intencionado é por vezes descrito como um zumbi.

Um host comprometido pode ser instalado com um ou mais bots. Um bot é um script ou ferramenta automatizados que executa algum tipo de atividade mal-intencionada. Um grupo de bots sob o controle da mesma instância de malware pode ser manipulado como uma botnet pelo programa controlador. Uma [[botnet]] pode ser usada para diversos propósitos mal-intencionados, incluindo o desencadeamento de ataques distribuídos de negação de serviço (DDoS), campanhas de spam ou mineração de criptomoedas.

Figura 1. RAT SubSeven



Captura de tela usada com permissão do Wikimedia Commons pela CCAS4.0 International.

Descrição

A tela exibe um botão expansível chamado connection, selecionado para listar os hiperlinks para ip scanner, get pc info, get home info, server options (selecionado) e ip notify. Os botões à direita são: change port, set default port, set password, remove password, disconnect victim, restart server, remove server, close server, update server from local file e update server from URL file. Outros botões expansíveis no canto inferior esquerdo são: keys or messages, advanced, miscellaneous, fun manager, extra fun e local options.

Seja um backdoor utilizado como mecanismo de intrusão independente ou para gerenciar bots, o agente de ameaça precisa estabelecer uma conexão do host comprometido para um host ou rede de [[comando e controle (C2 ou C&C)]]. Essa conexão de rede geralmente é a melhor maneira de identificar a presença de um RAT, backdoor ou bot. Existem muitos meios de implementar uma rede de C&C como um [[canal secreto]] para evitar a detecção e filtragem. Historicamente, o protocolo de [[bate-papo via internet (IRC)]] foi muito popular. Já os métodos modernos provavelmente usam sequências de comandos incorporadas no tráfego HTTPS ou DNS.

Nota:

As backdoors podem ser criadas de outras maneiras além da infecção por malware. Os programadores podem criar backdoors em aplicações de software para fins de teste e desenvolvimento que, posteriormente, não são removidas quando o aplicativo é implantado. As backdoors também são criadas quando há uma configuração incorreta de software ou hardware que permite acesso a usuários não autorizados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Cavalos de troia de acesso remoto usam de chamadas backdoors para poder driblar as formas comuns de autenticação para poderem acessar os sistemas e máquinas. Um deles tem o nome de RAT e é um malware de backdoor que utiliza de acessos remotos para ocultar sua funcionalidade maligna.

Com um host comprometido, pode ser instalado um botnet para realizar mineração de criptomoedas, campanhas de spam e ataques de negação de serviço distribuídas.

Para realizar essa ação, o agente de ameaça precisa ter uma conexão de duas pontas, chamamos de C2 ou C&C que é criada na rede, seria comando e controle.

No Windows, os malwares do tipo cavalo de troia se ativam mediante a execução manual pelo usuário conectado e herdam os privilégios dessa conta de usuário. Se a conta tiver apenas as permissões padrão, o malware só conseguirá adicionar, alterar ou excluir arquivos no perfil do usuário e executar apenas aplicativos e comandos permitidos ao usuário.

Se o malware tentar alterar arquivos ou configurações em todo o sistema, precisará de direitos de administrador local.

Para conseguir isso por meio da instalação ou execução manuais, o usuário deve confiar o bastante no pacote de cavalo de troia para confirmar o prompt de Controle de Conta de Usuário (UAC) ou inserir as credenciais de um usuário administrativo.

Se o malware ganhar direitos de administrador local, ainda há outras proteções no Windows para mitigar o uso indevido dessas permissões. Os processos críticos são executados com um nível mais elevado de direito de acesso chamado SYSTEM. Consequentemente, os cavalos de troia instalados ou executados com direitos de administrador local não conseguem ocultar totalmente sua presença e são exibidos como um processo ou serviço em execução. Muitas vezes, o nome da imagem do processo é configurado para se assemelhar a um arquivo executável ou biblioteca genuínos, a fim de evitar a detecção. Por exemplo, um cavalo de troia pode usar o nome de arquivo “rundll32.exe” para se passar pelo “rundll32.exe”. Para garantir a persistência (ser executado quando o computador for reiniciado), o cavalo de troia pode usar uma entrada de registro ou definir-se como um serviço, o que em geral pode ser detectado facilmente.

Se o malware conseguir ser entregue como o payload para explorar uma vulnerabilidade grave, ele poderá ser executado sem a necessidade de qualquer autorização usando direitos de SYSTEM. Opcionalmente, o malware pode aproveitar-se de uma exploração para elevar os direitos de acesso ao nível de SYSTEM após a instalação. Malwares

executados com esse nível de direito são chamados de [[rootkit]]. Esse termo vem do UNIX/Linux, onde qualquer processo sendo executado como a conta de superusuário root tem acesso irrestrito a tudo, do root do sistema de arquivos para baixo.

Em teoria, não há nada no sistema que um rootkit não possa mudar. Na prática, o Windows usa outros mecanismos para evitar o uso indevido dos processos de kernel, como a assinatura de código. Consequentemente, o que um rootkit consegue fazer depende em grande parte da capacidade do invasor e do nível de esforço. Ao lidar com um rootkit, você deve estar ciente de que ele pode comprometer arquivos de sistema e interfaces de programação, de modo que os processos de shell locais, como Explorer, taskmgr ou tasklist no Windows ou ps ou top no Linux, além de ferramentas de varredura de portas, como netstat, deixam de revelar a sua presença (pelo menos quando executados a partir da máquina infectada). Um rootkit também pode conter ferramentas para limpar os logs do sistema, ocultando ainda mais sua presença.

Nota:

Os processos de software podem ser executados em um de vários "rings.". O Ring 0 é o que tem mais direitos (fornece acesso direto ao hardware) e, portanto, deve ser reservado apenas para os processos de kernel. O Ring 3 é onde os processos em modo de usuário são executados; drivers e processos de E/S podem rodar no Ring 1 ou Ring 2. Essa arquitetura pode ser ainda mais complexa devido ao uso de virtualização.

Há também exemplos de rootkits que podem residir no firmware (o firmware do computador ou de qualquer tipo de placa de adaptador, disco rígido, unidade removível ou dispositivo periférico). Nesse caso, eles conseguem subsistir a qualquer tentativa de remoção por meio da formatação da unidade e reinstalação do sistema operacional. Por exemplo, as agências de inteligência dos EUA desenvolveram rootkits UEFI DarkMatter e Quark Matter para lidar com firmwares em notebooks Macbook da Apple.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Vimos até agora que vírus, malwares, worms e todo tipo de praga digital é horrível, não parece ter solução e é simplesmente uma porcaria. Olhando por outro lado, até que ela é difícil de causar muito estrago na máquina, pois mesmo que ela invada, vai ter permissão somente do usuário que dependendo qual é, talvez seja limitado para fazer algumas coisas só. Segundo que o usuário precisa confiar muito em um trojan para poder liberar o UAC para ele e terceiro, é que é possível visualizar o processo do trojan rodando no gerenciador de tarefas do Windows. Ele pode até tentar se esconder em nomes de dll famosas, mas conseguimos ver.

É aí que entra o rootkit, pois se um malware consegue explorar uma vulnerabilidade grave dentro do sistema, ele entra com permissão de elevação sem qualquer autorização usando direto o SYSTEM. O nome vem do Unix/Linux onde o usuário root tinha acesso irrestrito ao sistema tendo acesso dos arquivos para tudo a baixo. Catástrofe, né ?

Em teoria, não a nada que um rootkit não possa fazer dentro do sistema. No sistema operacional Windows, existem algumas defesas em que o agente de ameaça não possa acessar o kernal do sistema, como a assinatura de código. Aqui um pouco do risco dos rootkits:

Ao lidar com um rootkit, você deve estar ciente de que ele pode comprometer arquivos de sistema e interfaces de programação, de modo que os processos de shell locais, como Explorer, taskmgr ou tasklist no Windows ou ps ou top no Linux, além de ferramentas de varredura de portas, como netstat, deixam de revelar a sua presença (pelo menos quando executados a partir da máquina infectada). Um rootkit também pode conter ferramentas para limpar os logs do sistema, ocultando ainda mais sua presença.

Existem também rootkits que rodam dentro de um firmware por exemplo, onde qualquer disco rígido seja impedido de ser formatado. A agencia dos EUA desenvolvem um chamado UEFI DarkMetter.

[[Ransomware]] é um tipo de malware que tenta extorquir a vítima tornando o computador e/ou arquivos de dados indisponíveis e exigindo pagamento. Uma classe de ransomware exhibe mensagens ameaçadoras, por exemplo, pedindo para o Windows® ser reativado ou sugerindo que o computador foi bloqueado pela polícia por ter sido usado para ver pornografia infantil ou para terrorismo. Isso parece bloquear o acesso ao sistema de arquivos após instalar um programa shell diferente, mas esse tipo de ataque é relativamente simples de resolver.

O ransomware usa métodos de pagamento como transferências bancárias, criptomoedas ou linhas telefônicas com tarifas premium para permitir que o invasor consiga o dinheiro sem revelar sua identidade ou ser rastreado pelas autoridades locais.

Figura 1. Ransomware WannaCry



Imagem da Wikimedia Commons.

Descrição

Uma mensagem no topo diz: oops, seus arquivos foram criptografados. O texto abaixo responde às perguntas: o que aconteceu com meu computador, posso recuperar meus arquivos e como posso pagar. No lado esquerdo, são exibidas a data e a hora em que o valor do pagamento será aumentado e quando os arquivos serão perdidos. O texto na parte inferior diz: bitcoin aceito aqui. Envie 300 dólares em bitcoin para este endereço. Há um link com botão de copiar. Os botões “Verificar pagamento” e “Descriptografar” estão na parte inferior.

Nota:

Scareware refere-se a malwares que exibem mensagens alarmantes, muitas vezes disfarçadas para se parecerem com avisos genuínos do sistema operacional. O scareware tenta alertar o usuário sugerindo que o computador foi infectado ou está sob total controle alheio.

Ransomware de criptografia

A classe cripto de ransomware tenta criptografar arquivos de dados em unidades fixas, removíveis e de rede. Caso o ataque tenha sucesso, o usuário não conseguirá acessar os arquivos sem obter a chave de criptografia privada, que está com o invasor. Se bem-sucedido, esse tipo de ataque é extremamente difícil de resolver, a menos que o usuário tenha backups dos arquivos criptografados. Um exemplo de ransomware de criptografia é o Cryptolocker, um cavalo de troia que procura arquivos para criptografar e, em seguida, solicita à vítima que pague uma quantia dentro de um determinado prazo, após o qual o malware destrói a chave que permite a descriptografia.

Malware de cryptojacking

Outro tipo de malware de criptografia assume o controle dos recursos do host para minerar criptomoedas. Isso é chamado de “[mineração de criptomoedas]”, e o malware que comete o ato de forma mal-intencionada é classificado como *cryptojacking*. O número total de moedas dentro de uma criptomoeda é limitado pela dificuldade de realizar os cálculos necessários para cunhar uma nova moeda digital. Consequentemente, novas moedas podem ser muito valiosas, mas são necessários recursos de computação massivos para descobri-las. O cryptojacking geralmente é realizado em botnets.

Bombas lógicas.

Alguns tipos de malware não são acionados automaticamente. Após infectar um sistema, eles esperam por uma hora ou data pré-configurada (bomba-relógio) ou, então, por um evento do sistema ou do usuário ([bomba lógica]). As bombas lógicas também não precisam ser códigos de malware. Um exemplo típico é um administrador de sistemas descontente que deixa o script de uma armadilha que é executada caso sua conta seja excluída ou desativada. É improvável que um software antivírus detecte esse tipo de script ou programa mal-intencionado. Esse tipo de armadilha também é chamado de *mina*.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os scanners de antivírus (AV) funcionam com base no reconhecimento de códigos de malware conhecidos. O código do malware é armazenado como uma assinatura no banco de dados do scanner do antivírus. O banco de dados de assinaturas deve ser atualizado continuamente. Quando um arquivo é acessado, o antivírus intercepta a chamada e faz a varredura do arquivo. Se o resultado for igual a alguma das assinaturas, ele bloqueia o acesso ao arquivo, alerta o usuário e registra o evento.

Esse tipo de detecção baseada em assinatura ainda é importante para detectar ataques de malware comum, mas não é mais totalmente eficaz. Muitas vezes, as atividades mal-intencionadas só podem ser detectadas por meio do monitoramento de uma ampla gama de indicadores. O conhecimento desses indicadores é formado pelo estudo dos comportamentos dos invasores. O resultado dessa análise é descrito como uma tática, técnica ou procedimento (TTP):

- **Tática:** descrição geral de um comportamento de ameaça. Comportamentos como reconhecimento, persistência e “escalação de privilégios” são exemplos de táticas.
- **Técnica:** descrição de nível intermediário de como um invasor desempenha uma tática. Por exemplo, o reconhecimento pode ser realizado por meio de técnicas como varredura de rede ativa, varredura de vulnerabilidades e coleta de emails.
- **Procedimento:** descrição detalhada de como uma técnica é aplicada. Por exemplo, um autor de ameaças específico pode usar uma ferramenta em particular de maneira incomum para realizar a varredura de vulnerabilidades.

Para efeitos de exemplo de análise de TTP, considere o cenário em que uma gangue criminosa procura chantagear empresas infectando hosts com ransomware. Esse é o objetivo do autor da ameaça. Para atingir esse objetivo, ele implanta uma campanha, que inclui várias táticas, como reconhecimento, desenvolvimento de recursos, acesso inicial e execução. Na tática de acesso inicial, a gangue pode ter desenvolvido uma nova técnica para explorar uma vulnerabilidade em alguns softwares de monitoramento de rede usados por várias empresas. A análise de procedimentos revela exatamente como o software explorado é instalado nas redes da empresa por meio de um repositório infectado. Isso ativa a próxima tática da gangue (execução de malware).

Um [[indicador de comprometimento (IoC)]] é um sinal residual de que um ativo ou rede foi atacado ou continua a ser atacado. Ou seja, um IoC é uma evidência de um TTP. No cenário acima, os IoCs podem incluir: presença da versão comprometida do processo de monitoramento de rede, conexões com a rede de Comando e Controle (C&C), recursos de recuperação/cópia de segurança do sistema desativados, entradas de registro e vestígios de scripts para execução do ransomware, arquivos tornados inacessíveis por meio de criptografia com extensões de arquivo diferentes e notificações de extorsão.

Como existem muitos alvos e vetores diferentes em um ataque, também existem milhares de IoCs em potencial. Muitos TTPs e IoCs são bem conhecidos. Eles são documentados e publicados por pesquisadores de ameaças. Um dos exemplos mais conhecidos é o banco de dados MITRE ATT&CK(attack.mitre.org (<https://attack.mitre.org/>)). Ferramentas de varredura modernas geralmente são integradas a feeds de ameaças de TTPs e indícios publicados. Isso permite a varredura automatizada de comportamentos mal-intencionados em lugar da mera detecção de malwares baseada em assinatura.

Um IoC pode ser identificável de forma definitiva e objetiva, como por meio de uma assinatura de malware, mas muitas vezes os IoCs só podem ser descritos com certeza por meio da correlação de muitos pontos de dados. Como esses IoCs são frequentemente identificados por meio de padrões de atividade anômala, e não por eventos únicos, eles ficam mais abertos à interpretação e, portanto, é mais lento diagnosticá-los. Consequentemente, as plataformas de threat intelligence usam sistemas de inteligência artificial (IA) para realizar análises automatizadas. São esses sistemas que estão por trás dos recursos de detecção e resposta dos pacotes modernos de proteção contra ameaças.

Nota:

A rigor, um IoC é uma evidência de um ataque bem-sucedido. Por vezes, o termo “indicador de ataque” (IoA) também é usado para se referir a evidências de uma tentativa de invasão em andamento.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Dada a variedade de tipos de malware, existem muitos possíveis indícios de atividades mal-intencionadas. Alguns tipos de malware exibem alterações óbvias, como ajustes nas configurações do navegador ou pedidos de resgate. Se o malware for projetado para operar de forma oculta, é necessária uma análise detalhada do comportamento dos processos, do sistema de arquivos e da rede.

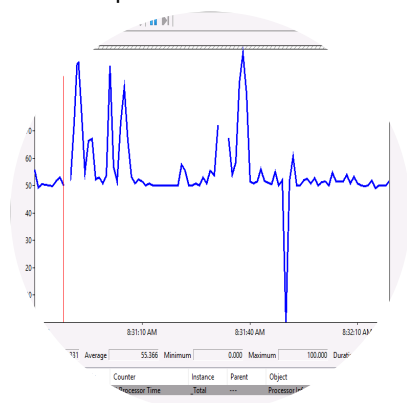
Execução de sandbox

Se a atividade maliciosa não for detectada pela proteção do endpoint, analise o código ou host suspeitos em uma sandbox. Uma sandbox é um sistema configurado em completo isolamento da rede de produção para que o malware não consiga “escapar”. A sandbox será projetada para registrar alterações no sistema de arquivos e no registro, além das atividades na rede. Da mesma forma, um “sheep dip” é um host isolado que se usa para testar novos softwares e mídias removíveis em busca de indícios de malware antes que esses programas e dispositivos sejam autorizados a acessar a rede de produção.

Consumo de recursos

O [[consumo anormal de recursos]] pode ser detectado usando um monitor de desempenho. Indicadores como uso excessivo e contínuo da CPU, vazamentos de memória, atividade de leitura/gravação em disco, uso de espaço em disco e consumo de largura de banda da rede podem ser sinais de malware. O consumo de recursos pode ser um motivo para investigar um sistema e não necessariamente é uma prova definitiva de atividades maliciosas. Esses sintomas também podem ser causados por muitos outros problemas de desempenho e estabilidade do sistema. Além disso, apenas malwares mal-escritos executam operações intensivas que exibem esse tipo de comportamento. Por exemplo, assumir o controle dos recursos do computador faz parte da natureza das botnets de DDoS, cryptojacking e ransomware de criptografia.

Figura 1. O Windows Performance Monitor grava a utilização da CPU no PC de um cliente. É difícil diagnosticar atividades anômalas, mas este gráfico mostra que a carga raramente cai abaixo de 50%. A carga contínua não é comum em um sistema cliente e pode indicar um malware de cryptojacking.



Captura de tela usada com permissão da Microsoft.

Sistema de arquivos

Um código malicioso pode não ser executado a partir de uma imagem de processo salva em um disco local, mas ainda é provável que interaja com o sistema de arquivos e o registro, revelando sua presença por meio do comportamento.

Um sistema de arquivos de computador armazena muitos metadados úteis sobre quando os arquivos foram criados, acessados ou modificados. A análise desses metadados e a verificação de arquivos temporários suspeitos podem ajudar a estabelecer uma linha do tempo de eventos relacionados a um incidente que deixou vestígios em um host e em seus arquivos.

Tentativas de acessar dados valiosos podem ser reveladas por meio de indicadores de [[conteúdo bloqueado]]. Quando os arquivos são simplesmente protegidos por listas de controle de acesso (ACL), se a auditoria estiver configurada, uma mensagem de acesso negado será registrada se uma conta de usuário tentar ler ou modificar um arquivo que não tem permissão para acessar. As informações também podem ser protegidas por um sistema de “prevenção de perda de dados”, que registrará eventos de conteúdo bloqueado.

Inacessibilidade de recursos

A [inacessibilidade de recursos] significa que uma rede, host, arquivo ou banco de dados não está disponível. Isso geralmente é indicador de um ataque de negação de serviço. Gateways de host e de rede podem não estar disponíveis devido ao consumo excessivo de recursos. Um ataque à rede geralmente cria um grande número de conexões. Os recursos de dados podem estar sujeitos a ataques de ransomware. Além disso, os malwares podem desativar os utilitários de varredura e monitoramento para evitar a detecção.

Comprometimento da conta

Um autor de ameaças geralmente tenta explorar uma conta existente para alcançar seus objetivos. Os seguintes indícios podem revelar um comportamento suspeito da conta:

- [[Bloqueio da conta]]: o sistema impede o acesso à conta porque foram feitas muitas tentativas de autenticação erradas. O bloqueio também pode indicar que a senha do usuário não funciona mais porque o autor da ameaça a alterou.
- [[Uso simultâneo da sessão]]: isto indica que o autor da ameaça obteve as credenciais da conta e está conectado em outra estação de trabalho ou por meio de uma conexão de acesso remoto.
- [[Viagem impossível]]: isto indica que o autor da ameaça está tentando acessar uma conta remotamente, a partir de um local ao qual não teria conseguido viajar fisicamente desde o último acesso.

Registro em log

Um autor de ameaças geralmente tentará encobrir seus rastros removendo os indicadores dos arquivos de log:

- [[Logs ausentes]]: pode significar que o arquivo de log foi excluído. Como isso é fácil de detectar, um autor de ameaças mais sofisticado removerá os logs. Isso pode ser indicado por lacunas incomuns entre os horários de inclusão do log. O tipo mais sofisticado de ataque falsificará as inclusões de log para ocultar a atividade maliciosa.
- [[Registro em log fora de ciclo]]: um autor de ameaças também pode manipular a hora do sistema ou alterar as marcações de data e hora do log como uma forma de ocultar a atividade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As instalações, os escritórios e as redes da empresa constituem uma ampla superfície de ataque para ataques perpetrados por autores de ameaças. Compreender como são perpetrados os ataques de negação de serviço, on-path e baseados em credenciais, e ser capaz de diagnosticar seus indicadores a partir de fontes de dados apropriadas, ajudará você a evitar e remediar eventos de intrusão.

Objetivos abordados na prova

- 2.4 Considerando determinado cenário, analisar os indicadores de atividade maliciosa.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O [[ataque físico]] é aquele direcionado contra a infraestrutura de cabeamento, os dispositivos de hardware ou o ambiente das instalações que hospedam a rede.

Força bruta

Um ataque físico de força bruta pode assumir várias formas diferentes, a exemplo destes:

- Smashing - Destruição física de um dispositivo de hardware para executar a negação de serviço (DoS) física.
- Invasão de instalações ou armários forçando uma fechadura ou portão de acesso. É provável que isso seja um indício de roubo ou adulteração.

Nota:

A prevenção de roubos geralmente é impossível de garantir, portanto, saber que algo foi roubado é importante para tomar providências como elaboração de relatórios de violações de dados e revogação de permissões de acesso. Um sistema inviolável exibirá sinais visíveis de entrada ou uso forçados que são difíceis para um autor de ameaças disfarçar.

Ambiental

Um [[ataque ao ambiente]] pode ser uma tentativa de executar a negação de serviço. Por exemplo, um autor de ameaças pode tentar destruir as linhas de energia, cortar os cabos da rede ou interromper os sistemas de resfriamento. Como alternativa, os sistemas de manutenção local e predial são vetores conhecidos pelos invasores ao tentar acessar as redes da empresa.

O risco proveniente de ataques físicos implica que as instalações devem ser monitoradas em busca de sinais de danos físicos ou da adição de dispositivos não autorizados.

RFID Cloning (clonagem RFID)

A [[ID de radiofrequência (RFID)]] é um meio de codificação de informações em etiquetas passivas. Quando um leitor adentra o perímetro de leitura da etiqueta, ele produz uma onda eletromagnética que ativa a etiqueta e lhe permite coletar informações dela. Essa tecnologia pode ser usada para implementar sistemas de controle de acesso a edifícios por aproximação.

Clonagem e raspagem de RFID referem-se a formas de falsificação de cartões ou crachás prediais de acesso por aproximação:

- [[Clonagem de crachá]]: refere-se à criação de uma ou mais cópias de um crachá existente. Um cartão perdido ou roubado sem proteções criptográficas pode ser duplicado fisicamente. A perda do cartão deve ser relatada imediatamente para que ele seja revogado e um novo, emitido. Se houve um ataque bem-sucedido, isso pode ser indicado pelo uso do crachá em um local ou horário suspeito.
- [[Raspagem]]: uso de um leitor falsificado para capturar detalhes do cartão ou crachá, que são usados para programar uma duplicata. Alguns tipos de crachás de proximidade podem ser facilmente induzidos a transmitir a credencial para um leitor RFID portátil que um ator de ameaça pode ocultar consigo.

Geralmente, estes ataques podem alvejar apenas cartões de acesso “imprudentes”, que transferem tokens estáticos em vez de executar o criptoprocessamento. Se o uso dos cartões for registrado, a indicação de comprometimento pode ser evidenciada por padrões de acesso de viagens impossíveis e uso simultâneo.

Nota:

A comunicação a curta distância (NFC) é derivada da RFID e também é frequentemente usada em cartões por aproximação. Ela funciona apenas a curta distância e permite comunicações bidirecionais entre pares NFC.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[ataque de rede]] é uma categoria geral que abrange uma série de estratégias e técnicas que os autores de ameaças usam para interromper ou obter acesso a sistemas por meio de um vetor de rede. A análise de ataques à rede geralmente se dá considerando o lugar que cada tipo de ataque pode ter dentro de um ciclo de vida geral do ataque cibernético:

- [[Reconhecimento]] é quando um autor de ameaças usa ferramentas de varredura para obter informações sobre a rede. A descoberta do host identifica quais endereços IP estão sendo usados. A descoberta de serviços identifica quais portas TCP ou UDP estão abertas em um determinado host. Fingerprinting identifica os tipos de aplicativos e as versões do software que operam em cada porta e, potencialmente, do sistema operacional em execução no host e seu tipo de dispositivo. A varredura rápida gera uma grande quantidade de tráfego de rede distinto que pode ser detectado e relatado como um evento de intrusão, mas é muito difícil diferenciar a atividade de varredura maliciosa da atividade de varredura não maliciosa.
- A [[coleta de credenciais]] é um tipo de reconhecimento em que o autor da ameaça tenta descobrir senhas ou segredos criptográficos que lhe permitirão obter acesso autenticado a sistemas de rede.
- A negação de serviço (DoS) em um contexto de rede refere-se a ataques que fazem com que hosts e serviços fiquem indisponíveis. Esse tipo de ataque pode ser detectado por ferramentas de monitoramento que relatam quando um host ou serviço não está respondendo ou está sofrendo de volumes de solicitações excepcionalmente altos. Um ataque DoS pode ser executado como fim em si mesmo ou para facilitar o sucesso de outros tipos de ataques.
- Armamento, entrega e violação referem-se a técnicas que permitem ao autor da ameaça obter acesso sem precisar de autenticação. Isso normalmente envolve vários tipos de código malicioso que é direcionado a um host ou serviço de aplicativo vulnerável por meio da rede ou, então, o envio de código oculto em anexos de arquivos e enganar um usuário para executá-lo.
- Comando e controle (C2 ou C&C), beaconing e persistência referem-se a técnicas e códigos maliciosos que permitem que um autor de ameaças opere um host comprometido remotamente e mantenha o acesso a ele por um tempo. O autor da ameaça precisa disfarçar o comando de entrada e a atividade de beaconing de saída como parte do tráfego regular da rede, por exemplo, usando conexões HTTPS criptografadas. A detecção desse tipo de atividade geralmente depende da identificação de endpoints de conexão anômalos, como conexões com endereços IP em países que não respeitam as leis de direitos autorais ou privacidade. Também pode haver indicadores no host comprometido, como o próprio malware e itens de inicialização não autorizados.
- [[Movimentação lateral]], [[pivoting]] escalção de privilégios referem-se a técnicas que permitem ao autor da ameaça mover-se de um host para outro dentro de uma rede ou de um segmento de rede para outro e obter permissões cada vez mais elevadas em sistemas e serviços em toda a rede. Esses tipos de ataques são detectados por meio de anomalias em logins de conta e uso de privilégios, mas a detecção geralmente depende de software com aprendizagem de máquina, pois normalmente é difícil diferenciar o comportamento anômalo do comportamento normal.
- A exfiltração de dados refere-se à obtenção de um ativo de informação e à sua cópia para a máquina remota do invasor. Transferências anômalas de dados volumosos podem ser um indicador de exfiltração, mas um autor de ameaças pode executar o ataque furtivamente, movendo apenas pequenas quantidades de dados em certos momentos.

Nota:

Observe que as etapas no ciclo de vida são iterativas. Por exemplo, um autor de ameaças pode realizar reconhecimento externo e coleta ou violação de credenciais para conquistar uma base de apoio. Ele pode então fazer o reconhecimento e a coleta de credenciais a partir da base de apoio para realizar a movimentação lateral e escalção de privilégios em hosts internos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[ataque de negação de serviço (DoS)]] é qualquer ação que reduza a disponibilidade de um recurso. Os ataques DoS podem ter como alvo o hardware físico e a infraestrutura. Um ataque DoS baseado em malware pode destruir um sistema de arquivos ou gerar consumo excessivo de CPU, memória, armazenamento ou largura de banda de rede.

Um ataque DoS também pode explorar vulnerabilidades de protocolo ou configuração em diferentes camadas de rede.

Os ataques DoS contra hosts e gateways de rede normalmente pertencem a um tipo chamado [[DoS distribuído (DDoS)]]. DDoS significa que o ataque é iniciado a partir de vários hosts simultaneamente. Normalmente, um autor de ameaças comprometerá as máquinas para usar como manipuladores em uma rede de comando e controle. Os manipuladores são usados para comprometer milhares ou milhões de hosts com ferramentas de bot DDoS, formando uma botnet.

Alguns tipos de ataques DDoS simplesmente visam consumir a largura de banda da rede, negando-a aos hosts legítimos. Para isso, usam um grande número de bots que fazem solicitações comuns. Outros causam esgotamento de recursos no host alvo bombardeando-o com solicitações, que consomem ciclos de CPU e memória. Isso atrasa o processamento do tráfego legítimo e pode travar o sistema host completamente. Por exemplo, um [[ataque de inundação SYN]] retém o pacote ACK do cliente durante o handshake de três vias de TCP. Um servidor, roteador ou firewall pode manter uma fila de conexões pendentes, registradas em sua tabela de estados. Quando não recebe um pacote ACK do cliente, ele reenvia o pacote SYN/ACK o número de vezes definido antes de expirar a conexão. O problema é que um servidor só consegue gerenciar um número limitado de conexões pendentes, que o ataque DDoS rapidamente preenche. Isso significa que o servidor não consegue responder ao tráfego original.

Ataques refletidos

Montar e gerenciar uma botnet grande o suficiente para sobrecarregar uma rede que possui medidas eficazes de mitigação de DDoS pode ser um empreendimento caro. Isso levou os autores das ameaças a desenvolver técnicas de DDoS que aumentam a eficácia de cada ataque. Em um ataque DoS refletido (DRDoS), o autor da ameaça falsifica o endereço IP da *vítima* e tenta abrir conexões com vários servidores externos. Esses servidores direcionam suas respostas SYN/ACK para o host da vítima. Isso consome rapidamente a largura de banda disponível da vítima.

Nota:

Uma ameaça assimétrica é aquela em que o autor da ameaça consegue perpetrar ataques eficazes, apesar de ter menos recursos do que a vítima.

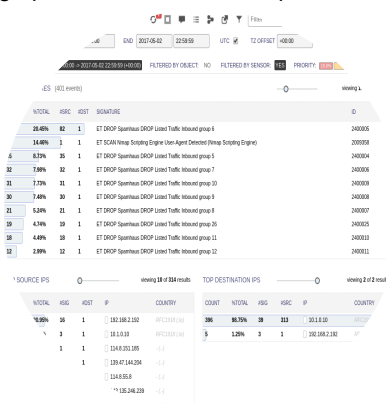
Ataques amplificad

Um ataque de amplificação é um tipo de ataque refletido que tem como alvo os pontos fracos nos protocolos de aplicativos específicos para tornar o ataque mais eficaz no consumo da largura de banda do alvo. Os ataques de amplificação exploram protocolos que permitem que o invasor manipule a solicitação de forma que o alvo seja forçado a responder com uma grande quantidade de dados. Os protocolos comumente alvejados são o sistema de nomes de domínio (DNS), o Network Time Protocol (NTP) e o Connectionless Lightweight Directory Access Protocol (CLDAP). Outro exemplo de um ataque especialmente eficaz explora o sistema de cache de banco de dados memcached usado por servidores web.

Indicadores de DDoS

Os ataques DDoS podem ser diagnosticados por picos de tráfego que não têm uma explicação legítima, mas geralmente só podem ser mitigados fornecendo serviços de alta disponibilidade, como balanceamento de carga e serviços em cluster. Em alguns casos, um firewall com estado pode detectar um ataque DDoS e bloquear automaticamente a origem. No entanto, em muitas técnicas usadas em ataques DDoS, os endereços de origem serão falsificados aleatoriamente ou iniciados por bots, dificultando a interrupção do ataque na origem.

Figura 1. Diminuição do tráfego proveniente de IPs bloqueados usando o IDS da Security Onion



Captura de tela usada com permissão da Security Onion.

Descrição

As três abas no topo são: eventos, resumo (selecionada) e visualizações. A data e hora de início e término estão listadas abaixo. Uma tabela intitulada principais assinaturas exhibe: quantidade, percentual total, hashtag de origem, hashtag de destino, assinatura e ID. As tabelas intituladas principais IPs de origem e principais IPs de destino exibem: quantidade, percentual total, hashtag de assinatura, hashtag de destino, IP e país.

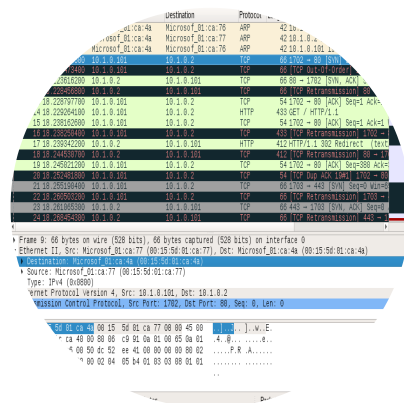


This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[ataque on-path]] é quando o autor da ameaça ganha uma posição entre dois hosts e captura, monitora e retransmite de maneira transparente toda a comunicação entre eles. Como o autor da ameaça retransmite as comunicações interceptadas, os hosts podem não ser capazes de detectar a presença do autor da ameaça. Um ataque on-path também pode ser usado para modificar secretamente o tráfego. Por exemplo, um host on-path pode apresentar uma estação de trabalho com um formulário de site falsificado para tentar capturar a credencial do usuário. Esse ataque também é conhecido como adversário no meio (AitM).

Os ataques on-path podem ser lançados em qualquer camada da rede. Um exemplo infame ataca a forma como o encaminhamento na camada 2 funciona em segmentos locais. O [[protocolo de resolução de endereços (ARP)]] identifica o endereço MAC de um host no segmento local que possui um endereço IPv4. Um ataque de [[envenenamento ARP]] utiliza uma ferramenta de criação de pacotes, como o Ettercap, para transmitir pacotes ARP de resposta não solicitados. Como o ARP não tem mecanismo de segurança, os dispositivos de recebimento confiam nessa comunicação e atualizam sua tabela de cache de endereços MAC:IP com o endereço falsificado.

Figura 1. Captura de pacotes aberta no Wireshark mostrando envenenamento de ARP



Captura de tela usada com permissão de [wireshark.org](https://www.wireshark.org) (<https://www.wireshark.org>).

Descrição

Uma tabela na parte superior lista: número, tempo, origem, destino, protocolo, comprimento e informações. No resultado abaixo, destino e protocolo de controle de transmissão estão destacados.

Esta captura de tela mostra os pacotes capturados durante um ataque típico de envenenamento de ARP:

- Nos quadros 6–8, a máquina invasora (com o endereço MAC de final :4a) direciona respostas ARP gratuitas para outros hosts (:76 e :77), alegando ter os endereços IP .2 e .102. Esse padrão de tráfego ARP infundado é um indicador do ataque.
- No quadro 9, o host .101/:77 tenta enviar um pacote para o host .2, mas ele é recebido pelo host invasor (com o MAC de destino :4a).
- No quadro 10, o host invasor retransmite o quadro 9 para o host .2 real. O Wireshark colore o quadro em preto e vermelho para destacar a retransmissão.
- Nos quadros 11 e 12, você pode ver a resposta de .2, recebida pelo host invasor no quadro 11 e retransmitida para o host legítimo no quadro 12.

O alvo habitual é o gateway padrão da sub-rede (o roteador que acessa outras redes). Se o ataque de envenenamento de ARP for bem-sucedido, todo o tráfego destinado a redes remotas será recebido pelo invasor, implementando um ataque on-path.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O sistema de nomes de domínio (DNS) resolve solicitações de hosts e serviços nomeados para endereços IP. A resolução de nomes é um método de endereçamento crítico na internet e em redes privadas. Há muitos ataques potenciais contra o DNS. Na internet pública, os ataques podem usar técnicas de typosquatting para fazer com que as vítimas confundam sites maliciosos com sites legítimos. O DNS pode ser explorado em um ataque DRDoS. Os autores de ameaças também podem alvejar diretamente os serviços de DNS público como um meio de realizar DoS contra um site ou recurso de nuvem. Por fim, um autor de ameaças pode conseguir desviar um servidor DNS público e inserir registros falsificados, direcionando as vítimas para sites mal-intencionados.

Em uma rede privada, é provável que um ataque DNS envolva algum tipo de [[envenenamento de DNS]]. O envenenamento de DNS compromete o processo pelo qual os clientes consultam os servidores de nomes para localizar o endereço IP de um nome de domínio. Existem várias maneiras de realizar um ataque de envenenamento de DNS.

Ataques on-path baseados em DNS

Se o autor da ameaça tiver acesso à mesma rede local da vítima, ele pode usar o envenenamento de ARP para responder a consultas DNS da vítima com respostas falsificadas. Isso pode ser combinado com um ataque de negação de serviço no servidor DNS legítimo da vítima. Um DHCP falso pode ser usado para configurar clientes com o endereço de um resolvedor de DNS controlado pelo autor da ameaça.

Envenenamento de cache do cliente DNS

Antes do desenvolvimento do DNS na década de 1980, a resolução de nomes ocorria usando um arquivo de texto chamado HOSTS. Cada mapeamento de nome:endereço IP era registrado nesse arquivo, e os administradores do sistema tinham que baixar a cópia mais recente e instalá-la manualmente em cada cliente ou servidor da internet. Embora a maioria da resolução de nomes agora funcione por meio do DNS, o arquivo HOSTS ainda está presente e a maioria dos sistemas operacionais o verifica antes de usar o DNS. Seu conteúdo é carregado em um cache de mapeamentos conhecidos de nome:endereço IP, e o cliente só entra em contato com um servidor DNS se o nome não estiver em cache. Portanto, se um invasor conseguir colocar um mapeamento falso de nome:endereço IP no arquivo HOSTS e efetivamente envenenar o cache DNS, ele poderá redirecionar o tráfego. A modificação do arquivo HOSTS requer acesso de administrador. Nos sistemas UNIX e Linux, ele é armazenado como `/etc/hosts`, e no Windows é colocado em `%SystemRoot%\System32\Drivers\etc\hosts`. A presença de entradas suspeitas no arquivo HOSTS é um indício de que a máquina foi comprometida.

Envenenamento de cache do servidor DNS

O envenenamento de cache do servidor DNS visa corromper os registros mantidos pelo próprio servidor DNS. É possível fazer isso executando o DoS contra o servidor que contém os registros autorizados para o domínio e, em seguida, falsificando respostas a solicitações de outros servidores de nomes. Outro ataque do tipo leva o servidor de nome da vítima a responder a uma consulta recursiva do host invasor. Uma consulta recursiva obriga o servidor DNS a consultar o servidor autoritativo para obter a resposta em nome do cliente. O invasor disfarça seu DNS como um servidor de nomes autoritativo e, ao responder à consulta, replica a resposta original, mas também inclui diversos mapeamentos falsos de domínio:IP para outros domínios, que o DNS da vítima acaba aceitando como legítimos. A ferramenta `nslookup` ou `dig` pode ser usada para consultar os registros de nome e os registros em cache mantidos por um servidor, a fim de descobrir se foram inseridos registros falsos.

Indicadores de ataque DNS

Um servidor DNS pode registrar um evento cada vez que processa uma solicitação para fazer a conversão entre um nome de domínio e um endereço IP. Os logs de eventos DNS podem conter uma variedade de informações que podem fornecer informações de segurança úteis e indícios de ataque, como os seguintes:

- Os tipos de consultas que um host fez ao DNS.
- Os hosts que estão em comunicação com endereços IP ou domínios suspeitos.
- Anomalias estatísticas, como picos ou um número consistentemente grande de falhas de pesquisa de DNS, que podem apontar para computadores infectados com malware, configurados incorretamente ou executando aplicativos obsoletos ou defeituosos.

Nota:

O DNS também é uma escolha popular para implementar o comando e controle (C&C) de cavalos de Troia de acesso remoto. Ele pode ser usado como um meio de exfiltrar secretamente dados de uma rede privada.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

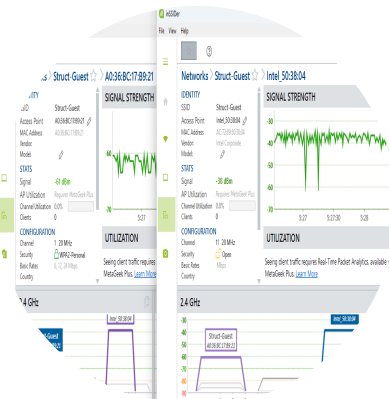
As redes wireless apresentam desafios de segurança específicos e são frequentemente o vetor de vários tipos de ataque.

Pontos de acesso mal intencionados

Um ponto de acesso malicioso é aquele que foi instalado na rede sem autorização, com más intenções ou não. Um usuário mal-intencionado pode configurar tal access point usando algo tão básico como um smartphone com recursos de compartilhamento, e um usuário comum pode habilitar esse access point acidentalmente. Se conectado a um segmento local, um access point não autorizado cria uma backdoor pela qual vai atacar a rede.

Um access point malicioso disfarçado de legítimo é chamado de evil twin. Cada rede é identificada para os usuários por um nome de Identificador de Conjunto de Serviço (SSID). Um [[evil twin]] pode usar técnicas como typosquatting ou SSID stripping para fazer com que o nome da rede maliciosa pareça semelhante ao legítimo. Como alternativa, o invasor pode usar alguma técnica DoS para superar o access point legítimo. No último caso, eles poderiam falsificar o SSID e o SSID básico (BSSID). O BSSID é o endereço MAC do rádio do access point. O evil twin pode conseguir coletar informações de autenticação de usuários que inserem suas credenciais por engano e implementar uma variedade de outros ataques on-path, incluindo o redirecionamento de DNS.

Figura 1. Levantamento de redes Wi-Fi usando o MetaGeek inSSIDer. A rede Struct-Guest mostrada na primeira janela é a legítima e tem a segurança WPA2 configurada. O evil twin tem o mesmo SSID, mas um BSSID (endereço MAC) diferente e autenticação aberta.



Um access point de hardware não autorizado pode ser identificado por meio de inspeções físicas. Existem também vários analisadores de Wi-Fi e sistemas de proteção contra intrusões wireless que podem detectar access points não autorizados. Estes podem registrar o uso de SSIDs relacionados a typosquatting e endereços MAC desconhecidos e duplicados (falsificados). Em uma rede corporativa, os access points geralmente são conectados a switches. O monitoramento pode detectar qualquer um que não esteja conectado e sinalizá-lo como possível invasor. Também podem identificar hardware de rádio e alertar caso seja detectado um access point não autorizado de uma marca específica.

Negação de serviço wireless

Um ataque de negação de serviço (DoS) a uma rede wireless geralmente é projetado para impedir que os clientes se conectem ao access point legítimo. Uma rede wireless pode ser interrompida pela interferência de outras fontes de rádio. Estas ações geralmente não são intencionais, mas também é possível que um invasor bloqueie propositalmente a rede legítima configurando um access point não autorizado com um sinal mais forte.

O DoS em wireless fio também pode atingir clientes. No curso normal das operações, um ponto de acesso e um cliente usam quadros de gerenciamento para controlar as conexões. Um [[ataque de desassociação]] explora a falta de criptografia no tráfego de quadros de gerenciamento para enviar quadros falsificados. Um tipo de ataque de desassociação injeta quadros de gerenciamento que falsificam o endereço MAC de uma única estação vítima em uma notificação de desassociação, fazendo com que ela seja desconectada da rede. Outra variante do ataque transmite quadros falsificados para desconectar todas as estações. Além de tentar redirecionar conexões para uma réplica maliciosa, um ataque de desassociação também pode ser usado em conjunto com um replay attack destinado a recuperar a chave de rede.

Wireless replay e recuperação de chaves

A autenticação sem fio é vulnerável a vários tipos de ataques de replay que visam capturar os hashes utilizados quando uma estação sem fio se associa a um ponto de acesso. Depois que o hash é capturado, ele pode ser submetido a tentativas de quebra por força bruta off-line e dicionário. Um ataque KRACK usa um mecanismo de repetição que tem como alvo o handshake de 4 vias WPA e WPA2. O KRACK é eficaz, independentemente de o mecanismo de autenticação ser pessoal ou corporativo. É importante garantir que clientes e access points estejam totalmente atualizados contra esses ataques.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Quando um usuário escolhe uma senha, o valor de texto simples é convertido em um hash criptográfico. Isso significa que, em teoria, ninguém, exceto o usuário (nem mesmo o administrador do sistema), sabe a senha, porque o texto simples não deve ser recuperável do hash. Um [[ataque de senha]] visa explorar os pontos fracos inerentes à seleção e gerenciamento de senhas para recuperar o texto simples e usá-lo na tentativa de comprometer uma conta.

Ataques online

Um *ataque de senha on-line* se dá quando o autor da ameaça interage diretamente com o serviço de autenticação, como um formulário de login na Web ou gateway VPN, por exemplo. Um ataque de senha on-line pode aparecer nos registros de auditoria como logins com falha repetida e, em seguida, um login bem-sucedido, ou como tentativas de login bem-sucedidas em horários ou locais incomuns. Além de garantir o uso de senhas fortes pelos usuários, a mitigação dos ataques de senhas on-line pode se dar restringindo o número ou a taxa de tentativas de login e evitando tentativas de login de endereços IP incorretos conhecidos.

Nota:

Observe que a restrição de logins pode se transformar em uma vulnerabilidade, pois expõe a conta a ataques de negação de serviço. O invasor continua tentando se autenticar, bloqueando usuários válidos.

Ataques offline

Um *ataque offline* significa que o invasor conseguiu obter um banco de dados de hashes de senha, como o %SystemRoot%\System32\config\SAM, % SystemRoot%\NTDS\NTDS.DIT (o armazenamento de credenciais do Active Directory) ou o /etc/shadow. Depois que o banco de dados de senha é obtido, o cracker não interage com o sistema de autenticação. O único indicador desse tipo de ataque (além do uso indevido da conta no caso de um ataque bem-sucedido) é um log de auditoria do sistema de arquivos que registra o acesso da conta mal-intencionada a um desses arquivos. Os autores de ameaças também podem ler credenciais na memória do host. Nesse caso, o único indicador confiável pode ser a presença de ferramentas de ataque em um host.

Se o invasor não puder obter um banco de dados de senhas, um “packet sniffer” pode ser usado para obter a resposta do cliente a um desafio do servidor em um protocolo de autenticação. Alguns protocolos enviam o hash diretamente; outros usam o hash para obter uma chave de criptografia. Lacunas nos protocolos que usam chaves obtidas podem permitir a extração do hash para quebra de sigilo.

Ataques de força bruta

Um [[ataque de força bruta]] tenta todas as combinações possíveis no espaço de saída para tentar parear um hash capturado e obter o texto simples que o gerou. O espaço de saída é determinado pelo número de bits usado pelo algoritmo (MD5 de 128 bits ou SHA256 de 256 bits, por exemplo). Quanto maior o espaço de saída e quanto mais caracteres forem usados na senha de texto simples, mais difícil é calcular e testar cada hash possível para encontrar uma correspondência. Os ataques de força bruta são fortemente limitados pelo tempo e recursos computacionais,

sendo, portanto, mais eficazes na quebra de senhas curtas. No entanto, ataques de força bruta distribuídos em vários componentes de hardware, como um cluster de placas gráficas de última geração, podem ser bem-sucedidos na quebra de senhas mais longas.

Ataques híbridos e de dicionário

Um [[ataque de dicionário]] pode ser usado quando há uma boa chance de adivinhar o valor provável do texto simples, como uma senha não complexa. O software gera valores de hash a partir de um dicionário de textos simples para tentar corresponder a um hash capturado. Um [[ataque de senha híbrida]] usa uma combinação de ataques de dicionário e força bruta. Ele é direcionado principalmente contra senhas ingênuas com complexidade inadequada, como `james1`. O algoritmo de quebra de senhas testa palavras do dicionário e nomes em combinação com uma máscara que limita o número de variações a serem testadas, como a adição de prefixos e/ou sufixos numéricos.

Spraying de senha

[[Password spraying (pulverização de senha)]] é um ataque on-line de força bruta horizontal. Isto é, o invasor escolhe uma ou mais senhas comuns (por exemplo, “`senha`” ou “`123456`”) e tenta essas senhas em conjunto com vários nomes de usuário.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um invasor pode estabelecer uma posição na rede comprometendo uma única estação de trabalho por meio de malware ou um ataque de senha. Uma vez que uma posição tenha sido conquistada, é provável que o objetivo do autor da ameaça seja identificar ativos de dados. Para isso, ele precisa encontrar formas de realizar movimentos laterais para comprometer outros hosts na rede e escalção de privilégios para obter mais permissões sobre os ativos da rede. Para atingir esses objetivos, além de quebrar mais senhas ou encontrar mais vulnerabilidades, ele pode usar [[credential replay attacks]] (ataques de repetição de credenciais).

Nota:

Em termos de ataques de rede, os credential replay attacks visam principalmente as redes do Windows Active Directory. Também existem credential replay attacks que visam aplicativos web. Discutiremos isso no próximo tópico.

Se uma conta de usuário em um host do Windows tiver sido autenticada em uma rede de domínio do Active Directory, o Serviço de Subsistema de Autoridade de Segurança Local (LSASS) armazenará vários segredos em cache na memória e no banco de dados de registro do Gerenciador de Contas de Segurança (SAM) para facilitar a autenticação única.

Estes segredos incluem:

- Tíquete de concessão de tíquetes Kerberos (TGT) e chave de sessão. Isso permite que o host solicite tíquetes de serviço para acessar aplicativos.
- Tíquetes de serviço para aplicativos em que o usuário iniciou uma sessão.
- Hash NT de contas de usuário e serviço locais e no domínio que no momento estão conectadas de forma interativa ou remotamente na rede. As primeiras redes empresariais do Windows usavam a autenticação por desafio e resposta do NT LAN Manager (NTLM). Embora o protocolo NTLM esteja obsoleto para a maioria das finalidades, o hash NT ainda é usado como formato de armazenamento de credenciais. O hash NT é usado quando a autenticação NTLM herdada ainda é permitida e pode atuar na assinatura de solicitações e respostas Kerberos.

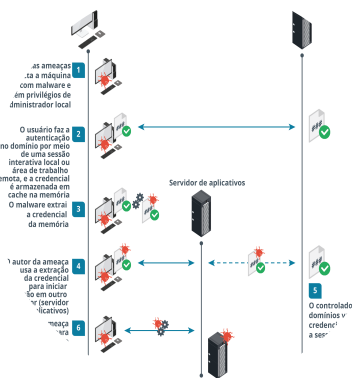
Crítico para a segurança da rede, se diferentes usuários estiverem conectados no mesmo host, as credenciais de todas essas contas podem ser armazenadas em cache pelo LSASS. Se algumas dessas contas forem de usuários mais privilegiados, como administradores de domínios, um autor de ameaças poderá usar as credenciais para ampliar os privilégios.

Nota:

O LSASS limpa os hashes da memória minutos após o usuário encerrar a sessão. O banco de dados SAM armazena em cache as credenciais de contas locais e da Microsoft, mas não as credenciais de domínio. Algumas edições do Windows implementam um recurso de virtualização chamado Credential Guard para proteger esses segredos de processos mal-intencionados, mesmo que tenham permissões do SYSTEM.

Os credential replay attacks usam vários mecanismos para obter e explorar esses segredos armazenados localmente para iniciar sessões autenticadas em outros hosts e aplicativos na rede. Por exemplo, se um autor de ameaças conseguir obter um hash NT, ele poderá usar um ataque pass the hash (PtH) para iniciar uma sessão em outro host se este estiver executando um serviço como compartilhamento de arquivos ou área de trabalho remota que ainda permita a autenticação NTLM.

Figura 1. O processo pass the hash. O Gerenciador de Contas de Segurança (SAM) é um banco de dados de registros do Windows que armazena credenciais de contas locais.



Descrição

The process involves four steps as follows:

1. Victim logs on. O DC (Controlador de Domínio) verifica o usuário por meio do Kerberos.
2. A vítima faz login novamente. As credenciais Kerberos são armazenadas em cache na memória do processo LSASS.
3. O invasor extrai a memória do LSASS no computador da vítima. As credenciais em cache são reveladas.
4. O invasor utiliza o hash em outro computador. As credenciais em hash são reconhecidas pelo Kerberos.

A autenticação NTLM herdada fica em geral desativada, pois é um risco de segurança muito alto. Outros tipos de credential replay são direcionados contra a autenticação e autorização do Kerberos. Por exemplo, um ataque “golden ticket” tenta falsificar um tíquete de concessão de tíquete. Se for bem-sucedido, concede ao autor da ameaça acesso praticamente ilimitado a todos os recursos do domínio. Um ataque “silver ticket” tenta falsificar tíquetes de serviço.

Ambos podem ser descritos como ataques pass the ticket (PtT).

A Microsoft lançou uma série de mitigações contra esses credential replay attacks específicos. Garantir que os hosts estejam totalmente atualizados e sigam bases de configuração seguras reduz muito sua eficácia. Quando ainda representam um risco, é possível configurar um sistema de detecção para correlacionar uma sequência de eventos de log de segurança, mas este método pode ser propenso a falsos-positivos. Antivírus e detecção de intrusão baseada em host geralmente conseguem detectar o código malicioso usado para extrair credenciais ou realizar ataques de falsificação de tíquetes.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os ataques que visam sistemas de autenticação geralmente dependem do sistema que usa criptografia fraca.

Ataques de downgrade

Um [[ataque de downgrade]] faz com que um servidor ou cliente use um protocolo de especificação inferior com cifras mais fracas e chaves mais curtas. Por exemplo, uma combinação de um ataque on-path e downgrade no HTTPS pode tentar forçar o cliente a usar uma versão fraca da segurança da camada de transporte (TLS) ou até mesmo fazer

downgrade para o protocolo legado secure sockets layer (SSL). Isso torna mais fácil para um autor de ameaças forçar o uso de conjuntos de cifras fracas e falsificar a assinatura de uma autoridade de certificação na qual o cliente confia.

Um tipo de ataque de downgrade é usado para atacar o Active Directory. Um ataque Kerberoasting tenta descobrir as senhas que protegem as contas de serviço obtendo tíquetes de serviço e submetendo-as a ataques de quebra de senha por força bruta. Se a parte da credencial do tíquete de serviço for criptografada usando AES, será muito difícil usar a força bruta. Se o ataque conseguir que o servidor retorne o tíquete usando criptografia RC4 fraca, é mais provável que um cracker possa extrair a senha do serviço.

É mais provável que as evidências de ataques de downgrade sejam encontradas nos logs do servidor ou por sistemas de detecção de intrusão.

Ataques de colisão

Uma [[colisão]] ocorre quando uma implementação ou função de hash criptográfica fraca permite a geração do mesmo valor de resumo para dois textos simples diferentes. Um ataque de colisão explora essa vulnerabilidade para falsificar uma assinatura digital. O ataque funciona da seguinte maneira:

1. O invasor cria um documento malicioso e um documento inofensivo que produzem o mesmo valor de hash.

O invasor envia o documento inofensivo para o alvo assinar.

2. Em seguida, o invasor remove a assinatura do documento inofensivo e a adiciona ao documento malicioso, falsificando a assinatura do alvo.

Um ataque de colisão pode ser usado para falsificar um certificado digital e enganar um site confiável ou para fazer parecer que o cavalo de troia malicioso veio de um editor confiável.

Ataques Birthday

Um ataque de colisão depende da capacidade de criar um documento malicioso que gera o mesmo hash que o documento inofensivo. Alguns ataques de colisão dependem da capacidade de manipular a forma como o hash é gerado. Um [[ataque Birthday]] é um meio de explorar colisões em funções hash por meio da força bruta. Força bruta significa tentar todas as combinações possíveis até obter sucesso. O ataque recebeu esse nome por causa do paradoxo do aniversário (birthday paradox). Esse paradoxo mostra que o tempo computacional necessário para forçar uma colisão pode ser menor do que o esperado.

O paradoxo do aniversário questiona quantas pessoas deve haver num dado grupo para que a probabilidade de duas delas compartilharem a mesma data de aniversário seja de 50%. A resposta é 23, mas as pessoas que não estão cientes do paradoxo geralmente respondem em torno de 180 ($365/2$). A questão é que as chances de alguém compartilhar a mesma data de aniversário são pequenas, mas as chances de duas pessoas em um grupo compartilharem a mesma data de nascimento em um ano civil aumentam à medida que adicionamos mais pessoas : $1 - (365 * (365 - 1) * (365 - 2) \dots * (365 - (N - 1)) / 365^N$.

Para explorar o paradoxo, o invasor cria vários documentos maliciosos e inofensivos com pequenas alterações (pontuação, espaços extras e assim por diante). Dependendo do tamanho do hash e dos limites para as alterações não suspeitas que podem ser introduzidas, se o invasor puder gerar variações suficientes, a probabilidade de corresponder às saídas de hash poderá ser maior que 50%. Isso significa efetivamente que uma função hash que gera hashes de 128 bits pode ser atacada por um mecanismo que pode gerar 264 variações. Calcular 264 variações levará muito menos tempo do que calcular 2128 variações.

Os ataques que exploram colisões são difíceis de iniciar, mas o princípio por trás deles trata da necessidade de usar métodos de autenticação que usem cifras fortes e implementações fortes de protocolo e software.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Muitos ataques de rede são iniciados por hosts comprometidos que executam vários tipos de código malicioso. Os indicadores de execução de código malicioso são capturados pelo software de proteção de endpoint ou descobertos após o fato nos logs que mostram como o malware interagiu com a rede, o sistema de arquivos e o registro. Para entender como e onde estes indicadores são gerados, é útil considerar os principais tipos de atividade mal-intencionada:

- **Shellcode:** é um trecho compacto de código usado como payload, projetado para explorar uma vulnerabilidade no sistema operacional ou em um aplicativo legítimo para obter privilégios não autorizados, ou criar um backdoor no host caso seja executado como um trojan. Depois de conquistar uma base de apoio, esse tipo de ataque é seguido por algum tipo de conexão de rede para baixar ferramentas adicionais.
- **Extração de credenciais:** o malware pode tentar acessar o arquivo de credenciais (SAM em uma estação de trabalho local do Windows) ou detectar credenciais armazenadas na memória pelo processo do sistema lsass.exe. Além disso, um ataque DCSync tenta enganar um controlador de domínio para replicar sua lista de usuários com suas credenciais com um host não autorizado.
- **Pivoting/movimento lateral/ataque interno:** o procedimento geral é usar a base de apoio para executar um processo remotamente, por meio de uma ferramenta como PsExec ou PowerShell. O invasor pode estar buscando ativos de dados ou pode tentar ampliar o acesso alterando a configuração de segurança do sistema, como abrir uma porta de firewall ou criar uma conta. Se o invasor tiver comprometido uma conta, estes comandos podem se misturar às operações comuns da rede, embora possam ser um comportamento anômalo para essa conta.
- **Persistência:** é um mecanismo que permite que a backdoor do invasor reinicie se o host for reiniciado ou o usuário fizer logout. Os métodos típicos são usar chaves AutoRun no registro, adicionar uma tarefa agendada ou usar assinaturas de eventos do Windows Management Instrumentation (WMI).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um aplicativo web expõe muitas interfaces a redes públicas. Os invasores podem explorar vulnerabilidades no software do servidor e na segurança do navegador do cliente para executar ataques de injeção e sequestro de sessão, que comprometem a confidencialidade e integridade dos dados. Compreender como são perpetrados esses ataques e ser capaz de diagnosticar seus indícios a partir de fontes de dados apropriadas ajudará você a evitar e remediar eventos de intrusão.

Objetivos abordados no exame:

- 2.4 Considerando determinado cenário, analisar os indicadores de atividade maliciosa.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[ataque de aplicativo]] visa uma vulnerabilidade no sistema operacional ou no software de aplicativo. Uma vulnerabilidade no aplicativo é uma falha de design que pode abrir lacunas no sistema de segurança do aplicativo ou que leve o aplicativo falhar. Existem, em geral, dois cenários principais para ataques a aplicativos:

- Comprometer o sistema operacional ou aplicativos de terceiros em um host de rede explorando cavalos de Tróia, anexos maliciosos ou vulnerabilidades do navegador. Isso permite que o autor da ameaça obtenha uma base de apoio em uma rede local.
- Comprometer a segurança de um site ou aplicativo web. Isso permite que um autor de ameaças obtenha o controle de um host web e roube dados dele ou use-o para tentar penetrar ainda mais na rede.

O aumento do número de falhas e erros de aplicativos pode fornecer um indício geral de que um autor de ameaças está tentando explorar uma vulnerabilidade em um serviço de rede, sistema operacional ou aplicativo de desktop ou aplicativo web. Os erros podem ser registrados em um log do sistema ou em um log específico do aplicativo, dependendo da natureza do software e do tipo de evento de falha. A utilização anômala da CPU, memória, armazenamento ou rede também pode ser um indício de ataque ao aplicativo. No entanto, esses indícios também podem ter várias causas não mal-intencionadas, por isso é importante correlacioná-los a fatores que identificam tipos específicos de ataques a aplicativos.

Escalção de privilégio

O objetivo da maioria dos ataques a aplicativos é permitir que o autor da ameaça execute seu próprio código no sistema. Isso é chamado de [[execução de código arbitrário]]. Quando o código é transmitido de uma máquina para outra, denomina-se execução [[remota de código]]. O código normalmente seria desenvolvido para instalar algum tipo de backdoor ou para desativar o sistema de alguma forma.

Um aplicativo ou processo deve ter privilégios para ler e gravar dados e executar funções. Dependendo de como o software registra gravações, um processo pode ser executado usando uma conta do sistema, a conta do usuário conectado ou uma conta designada. Se uma exploração de software funcionar, o invasor poderá executar um código arbitrário com o mesmo nível de privilégio do processo explorado. Existem dois tipos principais de [[escalção de privilégios]]:

- A [[escalção vertical de privilégios]] é quando um usuário ou aplicativo conseguem acessar funcionalidades ou dados que não deveriam estar disponíveis para eles. Por exemplo, um processo pode ser executado com privilégios de administrador local, mas uma vulnerabilidade permite que o código arbitrário seja executado com privilégios de SYSTEM mais elevados.
- A [[escalção horizontal de privilégios]] é quando um usuário acessa funcionalidades ou dados destinados a outro usuário. Por exemplo, por meio de um processo em execução com privilégios de administrador local em uma estação de trabalho do cliente, o código arbitrário pode ser executado como uma conta de domínio em um servidor de aplicativos.

Sem realizar uma análise detalhada do código ou da execução do processo em tempo real, é a escalção de privilégios que dá o indicador mais simples de um ataque a aplicativos. Se o registro em log dos processos tiver sido configurado, o log de auditoria poderá fornecer evidências de tentativas de escalção de privilégios. Estas tentativas também podem ser detectadas por agentes de resposta a incidentes e de proteção de endpoint, que exibirão um alerta.

Buffer overflow

Buffer é uma área da memória que um aplicativo reserva para armazenar algum valor. O aplicativo espera que os dados estejam em conformidade com algum tamanho ou formato de valor esperado. Para explorar uma vulnerabilidade de buffer overflow, o invasor passa dados que preenchem deliberadamente o buffer até o fim e, em seguida, sobrescreve os dados no início. Uma das vulnerabilidades mais comuns é um stack overflow. Stack é uma área da memória usada por uma sub-rotina de programa. Inclui um endereço de retorno, que é o local do programa que chamou a sub-rotina. Um invasor pode usar um buffer overflow para alterar o endereço de retorno, o que lhe permitirá executar um código arbitrário no sistema.

Os sistemas operacionais usam mecanismos como randomização de layout do espaço de endereçamento (ASLR) e prevenção de execução de dados (DEP) para mitigar os riscos decorrentes de buffer overflow. As tentativas fracassadas de buffer overflow podem ser identificadas por meio de falhas frequentes do processo e outras anomalias.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

No contexto de uma aplicação web, um replay attack geralmente envolve explorar sessões baseadas em cookies. HTTP é nominalmente um protocolo sem estado, ou seja, o servidor não preserva informações sobre o cliente. Para superar essa limitação e preservar dados com estado, mecanismos como cookies foram desenvolvidos. Um cookie é criado quando o servidor envia um cabeçalho de resposta HTTP com os dados do cookie. Um cookie tem um nome e valor, além de atributos opcionais de segurança e expiração. Os cabeçalhos de solicitação subsequentes enviados pelo cliente geralmente incluem o cookie. Os cookies podem ser não persistentes, caso em que são armazenados na memória e excluídos quando a instância do navegador é fechada, ou persistentes, caso em que são armazenados no cache do navegador até serem excluídos pelo usuário ou passarem da data de expiração definida.

O gerenciamento de sessões permite que uma aplicação web identifique especificamente o usuário em uma série de ações e solicitações diferentes. Um token de sessão identifica o usuário e também pode ser usado para provar que o usuário foi autenticado. Um [[replay attack]] captura ou adivinha o valor do token, depois o envia para restabelecer a sessão ilegalmente.

Figura 1. Uso do Browser Exploitation Framework (BeEF) para obter o cookie de sessão de um navegador.



Descrição

A lista de pastas à esquerda está intitulada “hooked browsers”. A aba do navegador atual, seguida pela aba de comandos, está selecionada à direita. A seção está dividida em três partes verticais: árvore de módulos (module tree), histórico de resultados de módulos (module results history) e resultados dos comandos (command results). A opção Get

cookie está selecionada sob o título árvore de módulos, e o histórico da árvore de módulos exibe a data e o rótulo.

Os invasores conseguem capturar cookies ao detectar o tráfego de rede por meio de um ataque on-path ou quando são enviados por meio de uma rede não segura, como um access point de Wi-Fi público. É provável que o malware que infecta um host também consiga capturar cookies. Os cookies de sessão também podem ser comprometidos por meio de Cross-Site Scripting (scripts entre sites - XSS).

Nota:

Cross-site scripting (XSS) é uma técnica de ataque que executa código malicioso em um navegador no contexto de um site ou aplicativo confiável.

Os ataques de previsão de sessão se concentram em identificar possíveis fraquezas na geração de tokens que permitirão ao invasor antecipar valores que estabelecerão sessões no futuro. Um token de sessão deve ser gerado usando um algoritmo não previsível e não deve revelar nenhuma informação sobre o cliente da sessão. Além disso, o gerenciamento adequado de sessões determina que os apps limitem a vida útil de uma sessão e exijam reautenticação após um determinado período.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Ao contrário dos replay attacks, um [[ataque de falsificação]] sequestra uma sessão autenticada para executar alguma ação sem o consentimento do usuário.

Falsificação de solicitação entre sites

Uma [[cross-site request forgery (falsificação de solicitação entre sites - XSRF - CSRF)]] pode explorar aplicativos que usam cookies para autenticar usuários e rastrear sessões. Para funcionar, o invasor deve convencer a vítima a iniciar uma sessão no site-alvo. Em seguida, ele passa uma solicitação HTTP ao navegador da vítima que falsifica uma ação no site de destino, como alterar uma senha ou um endereço de email. Essa solicitação pode ser disfarçada de maneiras que realizam o ataque sem que a vítima precise clicar em um link. Se o site de destino presumir que o navegador está autenticado porque há um cookie de sessão válido e não aplicar nenhum outro processo de autorização à entrada do invasor, ele aceitará a entrada como genuína. Isso também é chamado de ataque de confused deputy (representante confundido)

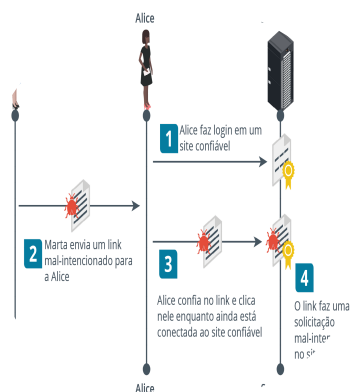


Figura 1. Exemplo de falsificação de solicitação entre sites

Imagens © 123RF.com.

Descrição

Os primeiros passos são:

1. Alice faz login em um site confiável.
2. Mallory envia um link malicioso para Alice.
3. Alice confia no link e clica nele enquanto ainda está conectada ao site confiável
4. O link faz uma solicitação maliciosa no site.

Falsificação de solicitação do lado do servidor

Uma [[server-side request forgery (falsificação de solicitação do lado do servidor - SSRF)]] faz com que um aplicativo de servidor processe uma solicitação arbitrária que tem como alvo outro serviço. O serviço de destino pode ser outro aplicativo em execução no mesmo host ou um serviço em execução em um host remoto. A SSRF explora tanto a falta de autenticação entre os servidores internos quanto os serviços. Ela também depende de uma fraca validação de entrada, o que permite ao invasor enviar solicitações arbitrárias.

Os ataques de SSRF geralmente são direcionados à infraestrutura em nuvem, em que o servidor Web é apenas o componente voltado para o público de uma cadeia de processamento mais profunda. Uma aplicação Web típica é composta por várias camadas de servidores, com uma interface de cliente, camadas lógicas de intermediárias (middleware) e uma camada de banco de dados. As solicitações iniciadas a partir da interface do cliente (um formulário da Web) provavelmente exigirão várias solicitações e respostas entre o middleware e os servidores de back-end. Elas serão implementadas como solicitações de cabeçalho HTTP e respostas entre cada servidor. A SSRF é um meio de acessar esses servidores internos, fazendo com que o servidor público execute solicitações neles. Enquanto na CSRF uma exploração tem apenas os privilégios do cliente, com SSRF a solicitação manipulada é feita com o nível de privilégio do servidor.

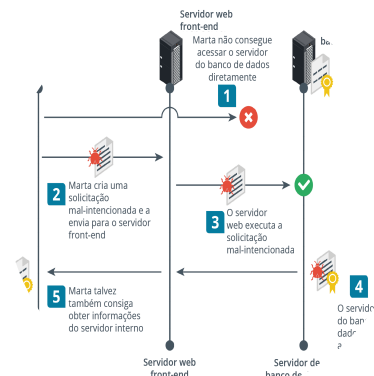


Figura 2. Exemplo de falsificação de solicitação do lado do servidor

Imagens © 123RF.com.

Descrição

Os primeiros passos são:

1. Marta não consegue acessar o servidor do banco de dados diretamente.
2. Marta cria uma solicitação mal-intencionada e a envia para o servidor front-end.
3. O servidor web executa a solicitação mal-intencionada.
4. O servidor do banco de dados aceita a solicitação porque ela parece vir do servidor web.
5. Mallory também pode obter informações do servidor interno.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Ataques como repetição de sessão, CSRF e a maioria dos tipos de XSS são ataques do lado do cliente. Isso significa que eles executam um código arbitrário no navegador. Um ataque do [[lado do servidor]] faz com que o servidor faça algum processamento ou execute um script ou consulta de uma forma não autorizada pelo design do aplicativo. A maioria dos ataques do lado do servidor depende de algum tipo de ataque de injeção.

Um [[ataque de injeção]] explora alguma maneira insegura pela qual o aplicativo processa solicitações e consultas. Por exemplo, um aplicativo pode permitir que um usuário visualize seu perfil com uma consulta ao banco de dados que deveria retornar apenas o registro único correspondente ao perfil desse usuário. Um aplicativo vulnerável a um ataque

de injeção pode permitir que um invasor obtenha os registros de todos os usuários ou altere campos no registro quando deveria apenas poder lê-los.

O XSS persistente e o abuso de consultas SQL e parâmetros discutidos anteriormente no curso são ambos tipos de ataque de injeção. Existem vários outros tipos de ataques de injeção que representam sérias ameaças às aplicações da Web e à infraestrutura.

Injeção de linguagem de marcação extensiva

A [[Extensible Markup Language (Linguagem de marcação extensiva - XML)]] é usada por aplicativos para autenticação e autorização e para outros tipos de troca e upload de dados. Os dados enviados via XML sem criptografia ou validação de entrada são vulneráveis a spoofing (falsificação), falsificação de solicitação e injeção de dados ou códigos arbitrários.

Por exemplo, um ataque de Entidade Externa XML (XXE) incorpora uma solicitação de um recurso local:

```
<?xml version="1.0" encoding="UTF-8"?>

<!DOCTYPE foo [<!ELEMENT foo ANY ><!ENTITY bar SYSTEM "file:///etc/config"> ]>

<bar>&bar;</bar>
```

Isso define uma entidade chamada bar que encaminha a um caminho de arquivo local. Um ataque bem-sucedido retornará o conteúdo de `/etc/config` como parte da resposta.

Injeção de LDAP (Lightweight Directory Access Protocol)

O Lightweight Directory Access Protocol (LDAP) é outro exemplo de linguagem de consulta. O LDAP é usado especificamente para ler e gravar bancos de dados de diretório de rede. Um invasor pode explorar o acesso não autenticado ou uma vulnerabilidade em um aplicativo cliente para enviar consultas LDAP arbitrárias. Isso pode permitir que as contas sejam criadas ou excluídas, ou que o invasor altere autorizações e privilégios.

Os filtros LDAP são construídos a partir de pares de atributos (nome=valor) delimitados por parênteses e os operadores lógicos E (&) e OU (|). A adição de parâmetros de filtro como entrada não sanitizada pode contornar os controles de acesso. Por exemplo, se um formulário da Web for autenticado em um diretório LDAP com as credenciais válidas Bob e Pa\$\$w0rd, ele poderá construir uma consulta como esta a partir da entrada do usuário:

```
(&(username=Bob)(password=Pa$$w0rd))
```

Os dois parâmetros devem ser verdadeiros para que o login seja aceito. Se a entrada do formulário não for sanitizada, um invasor pode contornar a verificação de senha inserindo um nome de usuário válido mais uma string de filtro LDAP, como **bob)(&))**. Isso faz com que o filtro de senha seja descartado para uma condição que é sempre verdadeira:

(& (username=Bob) (&))



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Directory traversal (diretório transversal)]] é outro tipo de ataque de injeção realizado contra um servidor Web. O invasor solicita um arquivo fora do diretório root do servidor Web informando um caminho para acessar o diretório principal (. . /) Esse ataque pode ser bem-sucedido se a entrada não for filtrada corretamente, e as permissões de acesso ao arquivo permitirem que o processo do servidor Web o leia, grave ou execute.

O invasor pode usar um [[ataque de canonicalization (canonização)]] para disfarçar a natureza da entrada maliciosa. A canonização refere-se à maneira como o servidor converte entre os diferentes métodos pelos quais um recurso pode ser representado e submetido ao método mais simples (ou canônico) usado pelo servidor para processar a entrada. Exemplos de esquemas de codificação incluem entidades HTML e codificação percentual de conjunto de caracteres. Um invasor pode conseguir explorar vulnerabilidades no processo de canonização para executar a injeção de código ou facilitar o diretório transversal. Por exemplo, para executar um ataque de diretório transversal, o invasor pode enviar um URL como o seguinte:

```
http://victim.foo/?show=../../../../etc/config
```

Uma rotina de validação de entrada limitada impediria o uso da string ../ e recusaria a solicitação. Se o invasor enviou o URL usando a versão codificada dos caracteres, ele pode conseguir burlar a rotina de validação:

```
http://victim.foo/?show=%2e%2e%2f%2e%2e%2f%2e%2e%2f%2e%2e%2fetc/config
```

Um [[ataque de injeção]] de comando tenta fazer com que o servidor execute comandos do shell do sistema operacional e devolva o resultado ao navegador. Assim como no diretório transversal, o servidor Web normalmente deve ser capaz de impedir que os comandos operem fora do diretório root do servidor e impedir que os comandos sejam executados com qualquer nível de privilégio que não seja o usuário “convidado” do servidor Web (que normalmente recebe apenas privilégios muito restritos). Um ataque de injeção de comando bem-sucedido encontraria alguma maneira de contornar essa segurança ou explorar um servidor Web que não está configurado corretamente.



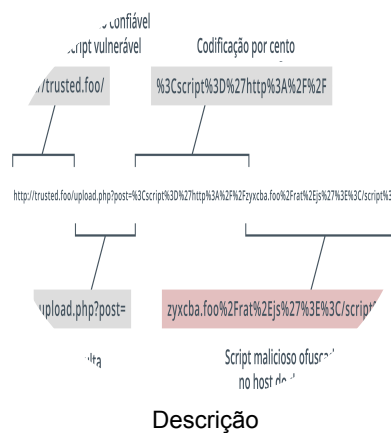
This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os ataques de sequestro/reprodução de sessão, falsificação e injeção são difíceis de identificar, mas os pontos de partida para a detecção provavelmente serão a análise do URL e o log de acesso do servidor Web.

Análise do localizador padrão de recursos

Além de apontar para o host ou local de serviço na Internet (por nome de domínio ou endereço IP), um [[Uniform Resource Locator (Localizador padrão de recursos - URL)]] pode codificar alguma ação ou dados a serem enviados ao host do servidor. Este é um vetor comum para atividades maliciosas.

Figura 1. Análise do localizador padrão de recursos (URL).



`http://trusted.foo/` (`http://trusted.foo/`) é a URL de um domínio confiável com um script vulnerável. `upload.php?post=` corresponde à query.

`%3Cscript%3D%27http%3A%2F%2F` é a codificação em percent-encoding.

`zyxcba.foo%2Frat%2Ejs%27%3E%3C/script%3E` é o domínio ofuscado que hospeda o script malicioso.

Como parte da análise do URL, é importante entender como o HTTP funciona. Uma sessão HTTP começa com um cliente (um agente de usuário, como um navegador da Web) fazendo uma solicitação a um servidor HTTP. A conexão estabelece uma conexão TCP. Essa conexão TCP pode ser usada para várias solicitações ou um cliente pode iniciar novas conexões TCP para diferentes solicitações. Uma solicitação normalmente compreende um método, um recurso (como um caminho de URL), número da versão, cabeçalhos e corpo. Os principais métodos são os seguintes:

- **GET**: recuperar um recurso.
- **POST** (enviar): enviar os dados para o servidor para processamento pelo recurso solicitado.
- **PUT** (colocar): criar ou substituir o recurso.

Os dados podem ser enviados a um servidor usando um método POST ou PUT e os cabeçalhos e corpo HTTP, ou codificando os dados dentro do URL usado para acessar o recurso. Os dados enviados por meio de uma URL são delimitados pelo caractere ?, que aparece após o caminho do recurso. Em geral, os parâmetros de consulta são formatados como um ou mais pares nome=valor, com e comercial (&) delimitando cada par.

A resposta do servidor compreende o número da versão e um código de status e mensagem, além de cabeçalhos opcionais e corpo da mensagem. Um código de resposta HTTP é o valor do cabeçalho retornado por um servidor quando um cliente solicita um URL, como 200 para “OK” ou 404 para “Não encontrado”.

Codificação por cento

Um URL pode conter apenas caracteres não reservados e reservados do conjunto padrão. Os caracteres reservados são usados como delimitadores dentro da sintaxe do URL e só devem ser usados de forma não codificada para esses fins. Os caracteres reservados são os seguintes:

: / ? # [] @ ! \$ % & ' () * + , ; =

Também existem caracteres não seguros, que não podem ser usados em um URL. Caracteres de controle, como terminação de string nula, mudança de linha, avanço de linha, fim de arquivo e tabulação, não são seguros. A codificação percentual permite que um user-agent (agente do usuário) envie qualquer caractere seguro ou inseguro (ou dados binários) ao servidor dentro do URL. Seus usos legítimos são codificar caracteres reservados dentro do URL quando eles não fazem parte da sintaxe do URL e enviar caracteres Unicode. A [[codificação percentual]] pode ser usada indevidamente para ofuscar a natureza de um URL (codificação de caracteres não reservados) e enviar entradas maliciosas.



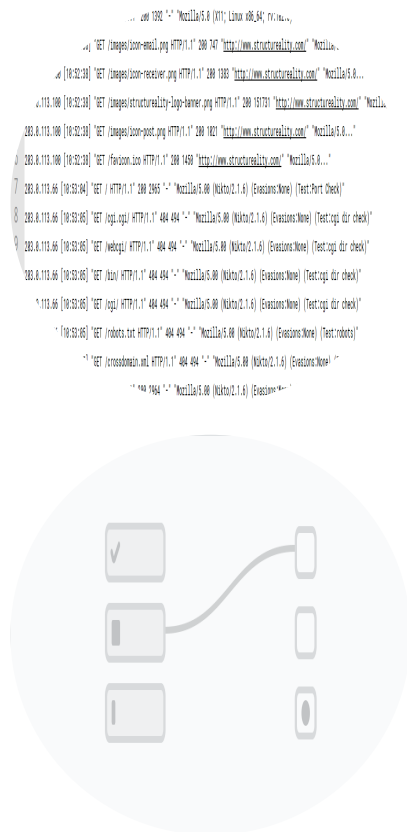
This content is only available on larger screen sizes. Please revisit this page on a larger device.

Normalmente, os servidores Web são configurados para registrar o tráfego HTTP que encontra um erro ou tráfego que corresponde a algum conjunto de regras predefinido. Isso pode preservar os indicadores de ataques tentativos e bem-sucedidos de repetição, falsificação e injeção.

O código de status de uma resposta pode revelar bastante sobre a solicitação e o comportamento do servidor. Códigos na faixa de 400 indicam erros baseados no cliente, enquanto códigos na faixa de 500 indicam erros baseados no servidor. Por exemplo, respostas repetidas 403 “Forbidden” (proibido) podem indicar que o servidor está rejeitando as tentativas de um cliente de acessar recursos aos quais não está autorizado. Uma resposta 502 “Bad Gateway” (Gateway incorreto) pode indicar que as comunicações entre o servidor de destino e seu servidor upstream estão sendo bloqueadas ou que o servidor upstream está inativo.

Além dos códigos de status, alguns softwares de servidor Web também registram informações de cabeçalho HTTP para solicitações e respostas. Isso pode fornecer uma imagem detalhada da composição de cada solicitação ou resposta, como informações sobre cookies.

Figura 1. Log de acesso ao servidor Web mostrando um cliente comum (203.0.113.66) acessando uma página e seus recursos de imagem associados e, em seguida, verificando a atividade do aplicativo Nikto em execução em 203.0.113.66. A atividade de varredura gera vários erros 404 ao tentar mapear a superfície de ataque do aplicativo Web enumerando diretórios e arquivos comuns.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de identificar os indicadores de tipos de ataque, como malware, físico, de rede, criptográfico, de senha e de aplicativo.

Diretrizes para implementar a análise de indicadores

Siga estas diretrizes para fazer a análise dos diferentes tipos de ataque:

- Considere a implementação de conjuntos de proteção de endpoint baseados em comportamento que possam realizar uma detecção mais eficaz de malware fileless.

- Considere a configuração de uma sandbox com ferramentas de análise para investigar o comportamento de processos suspeitos.
- Considere usar feeds de dados de ameaças para auxiliar na identificação de indicadores que já foram documentados e publicados.
- Implemente auditorias de inspeção e registro de atividades no site para identificar ataques físicos, como de força bruta, clonagem de RFID ou ambientais.
- Elabore manuais de procedimentos e threat intelligence para auxiliar na análise de ataques:
 - Consumo de recursos, anomalias no sistema de arquivos, inacessibilidade de recursos e indicadores de comprometimento do sistema baseados em registros ausentes ou fora de ciclo.
 - Indicadores de comprometimento de conta como impossibilidade de acesso, sessões simultâneas e indícios de deslocamentos impossíveis.
 - Características dos tipos de malware, como bloatware (software imposto), vírus, worm (verme de computador), cavalo de Troia (trojan), spyware (software espião), keylogger (registrador de teclas), ransomware (sequestro de dados) e logic bomb (bomba lógica).
 - Consumo de recursos dos dispositivos de rede indicadores de DDoS, incluindo os tipos refletidos e amplificados.
 - Monitoramento de rede e indicadores de registros (log) dos ataques tipo invasor intermediário (on-path), DNS, wireless, repetição de credenciais (credential replay), degradação criptográfica (cryptographic downgrade), pulverização de senhas (password spraying) e força bruta contra senhas.
 - Monitoramento e registro (log) do host indicadores de ataques tipo injeção, transbordamento de dados (buffer overflow), repetição (replay), escalação de privilégios, falsificação e diretório transversal (directory traversal ou path traversal) a aplicativos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.